

Protección y tratamiento de datos personales

Breve descripción:

Este componente formativo desarrolla los aspectos fundamentales de la protección de datos personales en Colombia. Aborda los principios, derechos, deberes y mecanismos de control establecidos en la Ley 1581 de 2012, así como su aplicación en las organizaciones para garantizar el tratamiento adecuado de la información y prevenir riesgos legales.

Tabla de contenido

Introducción	4
1. Fundamentos de la protección de datos personales	5
1.1. Concepto de protección de datos personales	7
1.2. Evolución de la protección de datos	11
1.3. Importancia organizacional de la protección de datos	13
2. Ley 1581 de 2012	16
2.1. Generalidades de la Ley 1581	16
2.2. Ámbito de aplicación	19
2.3. Definiciones fundamentales	21
3. Principios rectores para el tratamiento de datos	25
3.1. Principios relacionados con la legalidad	25
3.2. Principios relacionados con la calidad de la información	27
3.3. Principios relacionados con la protección de la información	30
4. Categorías especiales de datos personales	34
4.1. Clasificación de los datos personales	35
4.2. Datos sensibles	38
4.3. Datos de niños, niñas y adolescentes	42
5. Derechos y condiciones de legalidad para el tratamiento de datos	47

5.1. Derechos de los titulares	47
5.2. Autorización para el tratamiento de datos	52
5.3. Condiciones de legalidad	58
6. Responsables y encargados del tratamiento	63
6.1. Responsable del tratamiento.....	63
6.2. Encargado del tratamiento	66
6.3. Gestión organizacional del tratamiento de datos	70
7. Vigilancia, control y sanciones.....	75
7.1. Autoridades de control.....	75
7.2. Régimen sancionatorio.....	79
7.3. Gestión del riesgo legal	83
Síntesis	88
Glosario	89
Referencias bibliográficas	91
Créditos	92

Introducción

En la actualidad, la información personal constituye uno de los activos más valiosos para las personas, las organizaciones y la sociedad. El uso creciente de tecnologías digitales, plataformas en línea, aplicaciones móviles y sistemas de información ha incrementado la recolección, el almacenamiento y el intercambio de datos personales, haciendo indispensable la adopción de medidas que garanticen su tratamiento adecuado. En este contexto, la protección de los datos personales representa un elemento esencial para salvaguardar derechos fundamentales como la intimidad, la privacidad, el buen nombre y el habeas data.

Este componente formativo presenta los fundamentos de la protección de datos personales en Colombia, con énfasis en las disposiciones establecidas por la Ley 1581 de 2012 y su marco regulatorio. A lo largo del contenido se analizan los principios rectores, los derechos de los titulares, las responsabilidades de quienes intervienen en el tratamiento de la información, las categorías especiales de datos personales, las medidas de seguridad y los mecanismos que permiten garantizar el cumplimiento de la normativa vigente.

Asimismo, se promueve la aplicación práctica de estos conocimientos mediante el análisis de situaciones organizacionales que permiten identificar riesgos, adoptar medidas preventivas y fortalecer la gestión responsable de la información. De esta manera, el componente busca desarrollar las competencias necesarias para implementar buenas prácticas de protección de datos personales, contribuir al cumplimiento legal y fomentar una cultura organizacional basada en la transparencia, la seguridad de la información y el respeto por los derechos de los titulares.

1. Fundamentos de la protección de datos personales

A continuación, se presenta un video sobre la protección de datos personales, en el que se explican sus principios fundamentales, su importancia para la garantía de los derechos de las personas y su papel en la gestión responsable de la información dentro de las organizaciones.

Video 1. Protección de datos personales



[Enlace de reproducción del video](#)

Transcripción del video. Protección de datos personales

La información es uno de los recursos más valiosos para las personas y las organizaciones.

Actualmente, gran parte de las actividades diarias implica la recolección y el tratamiento de datos personales mediante formularios, aplicaciones móviles,

Transcripción del video. Protección de datos personales

plataformas digitales, redes sociales, sistemas de información y otros servicios en línea.

Esta realidad hace indispensable implementar medidas que protejan la información y garanticen un tratamiento seguro y responsable de los datos personales.

La protección de datos personales busca garantizar que la información de cada individuo sea tratada de manera legal, segura, transparente, responsable y de acuerdo con la normatividad vigente.

De esta manera, se protegen derechos fundamentales como la intimidad, la privacidad, el buen nombre y la autodeterminación informativa, permitiendo que cada persona mantenga el control sobre el uso de sus datos personales.

En las organizaciones, la protección de datos no solo representa el cumplimiento de una obligación legal, sino también una práctica esencial para fortalecer la confianza de clientes, usuarios, trabajadores y demás grupos de interés.

Además, una adecuada gestión de la información contribuye a prevenir riesgos, evitar sanciones y fortalecer una cultura organizacional basada en la responsabilidad, la transparencia y el respeto por la privacidad.

Por esta razón, aplicar buenas prácticas en el tratamiento de la información fortalece la confianza, protege los derechos de las personas y contribuye a una gestión organizacional segura y responsable.

1.1. Concepto de protección de datos personales

La protección de datos personales comprende el conjunto de principios, normas, procedimientos y medidas destinados a garantizar que la información de las personas sea tratada de manera adecuada y conforme con la normativa vigente. Su aplicación orienta las actividades de recolección, almacenamiento, uso, circulación, conservación y eliminación de los datos dentro de una organización.

El crecimiento de las tecnologías digitales y el intercambio constante de información han incrementado la necesidad de aplicar estos mecanismos de protección. Cada vez que una persona realiza una compra, diligencia un formulario, crea una cuenta en una plataforma digital o utiliza una aplicación móvil, genera datos que pueden ser tratados por organizaciones públicas o privadas.

Por esta razón, la protección de datos debe aplicarse durante todo el ciclo de vida de la información, desde su recolección hasta su eliminación, con el fin de garantizar que cada operación responda a una finalidad legítima y autorizada.

Información personal y privacidad

La información personal corresponde a cualquier dato que permita identificar o hacer identificable a una persona natural. Estos datos pueden presentarse de manera individual o combinarse con otros elementos para determinar la identidad de un individuo. Algunos ejemplos de información personal son los siguientes:

- **Datos de identificación.** Nombre, documento de identidad y firma.
- **Datos de contacto.** Dirección, teléfono y correo electrónico.
- **Datos laborales.** Cargo, empresa y experiencia profesional.
- **Datos financieros.** Cuenta bancaria e historial crediticio.

- **Datos biométricos.** Huella dactilar y reconocimiento facial.

Estas categorías permiten comprender que la información personal abarca diferentes ámbitos de la vida de una persona y que todos ellos requieren un tratamiento adecuado conforme a la legislación vigente.

La privacidad es el derecho que tiene cada persona para decidir quién puede acceder a su información y con qué finalidad puede utilizarla. Este derecho permite que los individuos mantengan el control sobre los datos relacionados con su vida personal, familiar, laboral y económica.

Ejemplo:

Una empresa solicita a sus trabajadores información relacionada con sus datos de contacto para gestionar procesos internos de comunicación. En este caso, la organización debe garantizar que la información sea utilizada únicamente para la finalidad informada y autorizada, y que no sea divulgada a terceros sin el consentimiento del titular o sin una causa legal que lo permita.

Este ejemplo permite comprender que la protección de la privacidad depende tanto del uso adecuado de la información como del cumplimiento de las obligaciones legales por parte de la organización.

Importancia de la protección de datos

La protección de datos personales resulta fundamental para fortalecer la confianza en las relaciones entre las personas y las organizaciones. Cuando una entidad administra adecuadamente la información, genera credibilidad, protege los derechos de los titulares y demuestra compromiso con el cumplimiento de la normativa. Entre

los principales beneficios de una adecuada protección de datos se encuentran los siguientes:

- Protección de la privacidad de las personas.
- Prevención del uso indebido de la información.
- Fortalecimiento de la confianza institucional.
- Cumplimiento de las obligaciones legales.
- Reducción de riesgos operativos y reputacionales.
- Mejoramiento de la gestión de la información.

Estos beneficios contribuyen al fortalecimiento de la gestión organizacional, favorecen la continuidad de los procesos y disminuyen la probabilidad de incidentes relacionados con el tratamiento de los datos personales.

Ejemplo:

Una institución educativa implementa controles de acceso a las bases de datos de estudiantes para garantizar que únicamente el personal autorizado pueda consultar o modificar la información académica. Esta medida protege la privacidad de los estudiantes, fortalece la seguridad de la información y reduce los riesgos asociados con accesos no autorizados o modificaciones indebidas.

Este caso evidencia que la implementación de controles de seguridad constituye una práctica esencial para garantizar la protección de los datos personales y fortalecer la confianza en la gestión institucional.

Riesgos asociados al manejo inadecuado de datos

El tratamiento inadecuado de los datos personales puede generar consecuencias negativas tanto para las personas como para las organizaciones. La pérdida, alteración, divulgación, acceso no autorizado o uso indebido de la información puede afectar derechos fundamentales, interrumpir procesos institucionales y ocasionar sanciones legales. Los riesgos más frecuentes y sus posibles consecuencias se relacionan a continuación:

- **Acceso no autorizado.** Exposición de información confidencial.
- **Robo de identidad.** Suplantación de personas.
- **Pérdida de información.** Interrupción de procesos.
- **Uso indebido de datos.** Vulneración de derechos.
- **Filtración de información.** Afectación reputacional.
- **Incumplimiento normativo.** Multas y sanciones.

La materialización de estos riesgos puede afectar la confidencialidad, la integridad y la disponibilidad de la información. Por esta razón, las organizaciones deben implementar medidas administrativas, técnicas y organizacionales que permitan identificar, evaluar, controlar y mitigar los riesgos durante todo el ciclo de vida de los datos personales.

Una adecuada gestión del riesgo fortalece el cumplimiento normativo, protege los derechos de los titulares y contribuye a preservar la continuidad de las operaciones institucionales.

1.2. Evolución de la protección de datos

La protección de datos personales ha evolucionado como respuesta al crecimiento de las tecnologías de la información y a la necesidad de regular el uso de la información personal. A medida que aumentó la capacidad para recopilar, almacenar y procesar datos, surgió la necesidad de establecer normas que garantizaran la protección de los derechos de las personas y promovieran un tratamiento responsable de la información.

Los avances tecnológicos han permitido que la información circule con rapidez entre organizaciones, plataformas y países. Esta realidad ha impulsado la creación de marcos normativos orientados a regular el tratamiento de los datos personales, fortalecer la seguridad de la información y promover el respeto por los derechos de los titulares. Los principales referentes que han marcado la evolución de la protección de datos personales se presentan a continuación:

- **Antecedentes internacionales.** La protección de los datos personales comenzó a consolidarse en el ámbito internacional como respuesta a la necesidad de regular el tratamiento de la información almacenada en sistemas automatizados. Instrumentos como la Declaración Universal de los Derechos Humanos, el Convenio 108 del Consejo de Europa, la Directiva Europea 95/46/CE y el Reglamento General de Protección de Datos (RGPD) establecieron principios y obligaciones que sirvieron de referencia para el desarrollo de las legislaciones nacionales orientadas a proteger la información personal.
- **Marco normativo colombiano.** En Colombia, la protección de datos personales tiene fundamento constitucional y legal. La Constitución Política

reconoce el derecho de las personas a conocer, actualizar y rectificar la información recopilada sobre ellas en bases de datos o archivos.

Posteriormente, diferentes disposiciones legales fortalecieron este derecho y establecieron obligaciones para quienes realizan el tratamiento de datos personales, promoviendo un manejo legal, transparente, seguro y responsable de la información.

- **Protección de datos en entornos digitales.** La transformación digital ha incrementado significativamente la generación, el almacenamiento y el intercambio de datos personales. Como consecuencia, han surgido riesgos como ciberataques, robo de credenciales, filtración de información, suplantación de identidad, fraudes electrónicos y uso indebido de datos personales. Para enfrentar estos desafíos, las organizaciones deben implementar controles de seguridad, políticas institucionales y mecanismos de protección que garanticen la confidencialidad, la integridad y la disponibilidad de la información durante todo su ciclo de vida.

Cada uno de estos aspectos ha contribuido al fortalecimiento de la protección de datos personales, permitiendo que las organizaciones desarrollen mecanismos cada vez más efectivos para garantizar el respeto por los derechos de los titulares y el cumplimiento de las obligaciones legales. Ejemplo: Una empresa de servicios solicita autorización previa a sus clientes antes de enviar comunicaciones comerciales. Esta práctica refleja la aplicación del marco normativo sobre protección de datos personales, ya que informa la finalidad del tratamiento y obtiene el consentimiento del titular antes de utilizar su información para actividades comerciales.

Ejemplo:

Una empresa de servicios solicita autorización previa a sus clientes antes de enviar comunicaciones comerciales. Esta práctica refleja la aplicación del marco normativo sobre protección de datos personales, ya que informa la finalidad del tratamiento y obtiene el consentimiento del titular antes de utilizar su información para actividades comerciales.

1.3. Importancia organizacional de la protección de datos

La protección de datos personales constituye un elemento estratégico para las organizaciones modernas. Una adecuada gestión de la información fortalece la confianza, promueve la transparencia y contribuye a la sostenibilidad institucional, al tiempo que favorece el cumplimiento de las obligaciones legales relacionadas con el tratamiento de los datos personales.

Las organizaciones que implementan prácticas responsables de tratamiento de datos mejoran sus procesos internos, reducen riesgos y fortalecen la relación con clientes, usuarios, trabajadores, proveedores y demás grupos de interés. Los principales aspectos que evidencian la importancia organizacional de la protección de datos son los siguientes:

- **Confianza y reputación corporativa.** La confianza constituye uno de los activos más importantes de una organización. Los clientes, usuarios, trabajadores y demás grupos de interés esperan que su información sea tratada de manera segura y responsable. Una adecuada gestión de los datos fortalece la reputación institucional, incrementa la credibilidad y favorece la

construcción de relaciones duraderas basadas en la transparencia y el respeto por la privacidad.

- **Cumplimiento normativo.** El cumplimiento de las disposiciones relacionadas con la protección de datos personales permite reducir riesgos legales y prevenir sanciones derivadas del incumplimiento de la normativa vigente. Para ello, las organizaciones deben establecer políticas, procedimientos, controles y mecanismos de seguimiento que garanticen un tratamiento adecuado de la información durante todo su ciclo de vida.
- **Responsabilidad institucional.** La responsabilidad institucional implica promover una cultura organizacional orientada a la protección de la información. Este compromiso involucra a directivos, trabajadores, proveedores, contratistas y terceros que participen en el tratamiento de datos personales. La protección de los datos debe asumirse como una práctica permanente que fortalece la ética organizacional, la seguridad de la información y el respeto por los derechos de los titulares.

Estos aspectos evidencian que la protección de datos personales trasciende el cumplimiento de una obligación legal y se convierte en un factor que fortalece la gestión organizacional, la confianza institucional y la sostenibilidad de las organizaciones.

Actividades de aplicación y análisis de la protección de datos personales

Se invita a leer el documento Actividades de aplicación y análisis de la protección de datos personales que se encuentra en la carpeta de anexos, donde se aborda la aplicación práctica de los principios, derechos, obligaciones y medidas relacionadas con

la protección de datos personales mediante casos de estudio y una actividad de diagnóstico organizacional.

2. Ley 1581 de 2012

La protección de los datos personales en Colombia se encuentra regulada principalmente por la Ley 1581 de 2012, norma que establece las disposiciones generales para la protección de la información personal, define los derechos de los titulares y determina las obligaciones de las organizaciones que realizan el tratamiento de datos personales.

Esta ley surge como respuesta a la necesidad de garantizar el derecho constitucional de las personas a conocer, actualizar y rectificar la información recopilada sobre ellas en bases de datos o archivos. Su aplicación se ha convertido en un elemento fundamental para el desarrollo de actividades comerciales, administrativas, financieras, educativas y tecnológicas que requieren la recolección y el uso de información personal.

En la actualidad, prácticamente todas las organizaciones gestionan datos personales de clientes, trabajadores, proveedores, usuarios o ciudadanos. Por esta razón, el conocimiento de la Ley 1581 de 2012 constituye una herramienta indispensable para garantizar el cumplimiento normativo, fortalecer la confianza institucional y prevenir riesgos asociados con el tratamiento inadecuado de la información.

2.1. Generalidades de la Ley 1581

La Ley 1581 de 2012 establece el marco jurídico general para la protección de los datos personales en Colombia. Su propósito consiste en garantizar que el tratamiento de la información se realice respetando los derechos fundamentales de los titulares y

promoviendo prácticas responsables por parte de quienes administran los datos personales.

La norma regula las actividades relacionadas con la recolección, el almacenamiento, el uso, la circulación y la supresión de datos personales, estableciendo criterios que permiten equilibrar el aprovechamiento de la información con la protección de la privacidad. Las principales generalidades de la Ley 1581 de 2012 se presentan a continuación:

- **Objeto de la ley.** La Ley 1581 de 2012 desarrolla el derecho constitucional que tienen todas las personas a conocer, actualizar y rectificar la información recopilada sobre ellas en bases de datos o archivos. Este propósito se relaciona directamente con el derecho fundamental al habeas data, entendido como la facultad que tiene cada persona para ejercer control sobre su información personal. La norma busca garantizar que los datos personales sean tratados de manera transparente, legítima y segura, evitando prácticas que puedan afectar la intimidad, el buen nombre y demás derechos fundamentales.
- **Finalidad de la norma.** La ley establece las condiciones necesarias para que el tratamiento de los datos personales se realice bajo criterios de legalidad, seguridad y responsabilidad. Para ello, promueve la implementación de mecanismos orientados a proteger la información, garantizar el uso adecuado de los datos, respetar los derechos de los titulares, reducir riesgos de acceso no autorizado y fortalecer la confianza en las relaciones entre las organizaciones y los titulares de la información. Asimismo, fomenta la

adopción de políticas y procedimientos que permitan administrar adecuadamente los datos personales durante todo su ciclo de vida.

- **Alcance jurídico.** La Ley 1581 de 2012 aplica a las actividades relacionadas con el tratamiento de datos personales realizadas por organizaciones públicas y privadas dentro del territorio colombiano. Establece obligaciones para quienes recopilan, almacenan, utilizan, comparten o eliminan información personal, independientemente de su naturaleza o tamaño. Además, permite que los titulares ejerzan sus derechos frente a los responsables y encargados del tratamiento, e incorpora mecanismos de supervisión, vigilancia y control para verificar el cumplimiento de la normativa y aplicar las sanciones correspondientes cuando sea necesario.

Estos aspectos permiten comprender el alcance de la Ley 1581 de 2012 y su importancia como fundamento del régimen colombiano de protección de datos personales.

Aplicación práctica

Cuando una empresa solicita información a sus clientes para realizar un proceso de venta, debe informar de manera clara la finalidad para la cual utilizará los datos personales y garantizar que el tratamiento se ajuste a la autorización otorgada por el titular. Los elementos que conforman el objeto de la Ley 1581 de 2012 se relacionan a continuación:

- **Protección de datos.** Garantizar el respeto por la información personal.
- **Habeas data.** Permitir que el titular ejerza control sobre su información.
- **Privacidad.** Salvaguardar la intimidad de las personas.

- **Transparencia.** Promover un tratamiento claro, verificable y responsable de la información.

Ejemplo: Una institución financiera recopila información de sus clientes para la apertura de productos bancarios. Antes de realizar el tratamiento de los datos, informa qué información será recopilada, con qué finalidad será utilizada, durante cuánto tiempo será conservada y cuáles son los derechos que pueden ejercer los titulares sobre sus datos personales.

Una institución financiera recopila información de sus clientes para la apertura de productos bancarios. Antes de realizar el tratamiento de los datos, informa qué información será recopilada, con qué finalidad será utilizada, durante cuánto tiempo será conservada y cuáles son los derechos que pueden ejercer los titulares sobre sus datos personales.

Los principales beneficios derivados de la finalidad de la norma se presentan a continuación:

- **Seguridad jurídica.** Favorece el cumplimiento de las obligaciones legales.
- **Transparencia.** Fortalece la confianza de los titulares en la organización.
- **Control de riesgos.** Reduce la probabilidad de incidentes relacionados con el tratamiento de datos personales.
- **Protección de derechos.** Garantiza el respeto por la privacidad y los derechos de los titulares.

2.2. Ámbito de aplicación

El ámbito de aplicación define las situaciones, las organizaciones y los tipos de información sobre los cuales la Ley 1581 de 2012 produce efectos jurídicos.

Comprender este aspecto permite determinar cuándo una organización debe cumplir las disposiciones relacionadas con la protección de datos personales y cuáles son sus responsabilidades frente a los titulares de la información. Los principales elementos que determinan el ámbito de aplicación de la Ley 1581 de 2012 se presentan a continuación:

- **Sujetos obligados.** Son todas las personas naturales o jurídicas, entidades públicas o privadas, que realicen actividades relacionadas con el tratamiento de datos personales. Entre ellas se encuentran empresas privadas, entidades gubernamentales, instituciones educativas, entidades de salud, organizaciones sin ánimo de lucro, plataformas digitales y comercios electrónicos. Su obligación surge desde el momento en que recopilan, almacenan, utilizan, comparten o eliminan datos personales en desarrollo de sus actividades.
- **Datos cubiertos por la ley.** La Ley 1581 de 2012 protege toda información vinculada o que pueda asociarse a una persona natural determinada o determinable. Entre los datos protegidos se encuentran los nombres y apellidos, el número de identificación, la dirección, el teléfono, el correo electrónico, la información financiera, la información laboral y los datos biométricos. La protección no depende únicamente de la naturaleza del dato, sino también de la posibilidad de identificar directa o indirectamente a una persona.
- **Excepciones de aplicación.** Aunque la ley tiene un amplio alcance, existen situaciones en las cuales sus disposiciones no resultan aplicables. Entre las principales excepciones se encuentran las bases de datos de uso

exclusivamente personal o doméstico, la información relacionada con la seguridad y la defensa nacional, la información de inteligencia y contrainteligencia, la información periodística y las bases de datos reguladas por normas especiales. Estas excepciones buscan armonizar la protección de los datos personales con otros intereses legítimos reconocidos por el ordenamiento jurídico.

Para comprender mejor quiénes se consideran sujetos obligados, se presentan algunos ejemplos de organizaciones y los tipos de datos personales que habitualmente tratan:

- **Empresa comercial.** Datos de clientes y proveedores.
- **Universidad.** Datos de estudiantes y docentes.
- **Hospital.** Datos de pacientes.
- **Banco.** Datos de clientes y usuarios del sistema financiero.
- **Empresa tecnológica.** Datos de usuarios de plataformas digitales.

Ejemplo Una empresa que almacena hojas de vida de candidatos para futuros procesos de selección se considera sujeto obligado, ya que realiza actividades relacionadas con el tratamiento de datos personales. En consecuencia, debe cumplir las disposiciones establecidas en la Ley 1581 de 2012, garantizar la protección de la información y respetar los derechos de los titulares.

2.3. Definiciones fundamentales

Las definiciones establecidas por la Ley 1581 de 2012 permiten interpretar correctamente los derechos, las obligaciones y las responsabilidades relacionadas con el tratamiento de datos personales. Su comprensión facilita la aplicación de la

normativa y contribuye a una gestión adecuada de la información en las organizaciones.

Los conceptos fundamentales de la Ley 1581 de 2012 se presentan a continuación:

- **Titular de la información.** Es la persona natural cuyos datos personales son objeto de tratamiento. Constituye el sujeto principal de protección dentro de la ley y puede ejercer derechos como conocer la información almacenada sobre ella, solicitar su actualización, rectificar datos inexactos, revocar la autorización otorgada y solicitar la supresión de la información cuando sea procedente conforme a la normativa vigente.
- **Responsable y encargado del tratamiento.** El responsable del tratamiento es la persona natural o jurídica, pública o privada, que decide sobre la finalidad y el uso de los datos personales. El encargado del tratamiento es quien realiza el tratamiento de los datos por cuenta del responsable y siguiendo sus instrucciones. Aunque ambos participan en el tratamiento de la información, sus funciones y responsabilidades son diferentes y complementarias.
- **Tratamiento de datos personales.** Corresponde a cualquier operación o conjunto de operaciones realizadas sobre datos personales. Comprende actividades como la recolección, el registro, la organización, el almacenamiento, la consulta, el uso, la circulación, la actualización, la conservación y la supresión de la información. Todas estas actividades deben desarrollarse respetando los principios, derechos y obligaciones establecidos en la Ley 1581 de 2012.

Las diferencias entre el responsable y el encargado del tratamiento permiten identificar el papel que desempeña cada uno dentro de la gestión de los datos personales:

Tabla 1. Diferencias entre el responsable y el encargado del tratamiento de datos personales

Responsable del tratamiento	Encargado del tratamiento
Define la finalidad del tratamiento de los datos.	Ejecuta las instrucciones impartidas por el responsable.
Decide sobre la recolección, el uso y la administración de la información.	Administra y opera los datos personales por cuenta del responsable.
Asume las principales obligaciones legales frente a los titulares y las autoridades competentes.	Apoya la operación del tratamiento y debe cumplir las instrucciones y medidas de seguridad definidas por el responsable.

El tratamiento de los datos personales comprende diferentes actividades que se desarrollan durante todo el ciclo de vida de la información:

- **Recolección.** Obtención de los datos personales del titular mediante los mecanismos autorizados.
- **Almacenamiento.** Conservación de la información en bases de datos o sistemas de información.
- **Uso.** Empleo de los datos para la finalidad previamente autorizada.
- **Circulación o compartición.** Transferencia o comunicación de la información cuando exista autorización o fundamento legal.
- **Conservación.** Mantenimiento de los datos durante el tiempo necesario para cumplir la finalidad del tratamiento y las obligaciones legales.
- **Supresión.** Eliminación de los datos cuando desaparezca la finalidad del tratamiento o exista obligación legal para hacerlo.

Ejemplo 1:

Un cliente solicita a una empresa la actualización de su dirección de correo electrónico. Con esta acción ejerce su derecho como titular de la información, al solicitar la modificación de un dato personal que forma parte de la base de datos de la organización.

Ejemplo 2:

Una empresa contrata a un proveedor tecnológico para alojar su base de datos de clientes. En esta situación, la empresa actúa como responsable del tratamiento, porque determina la finalidad y el uso de los datos personales, mientras que el proveedor tecnológico actúa como encargado del tratamiento, ya que administra la información siguiendo las instrucciones definidas por la empresa.

Actividades de aplicación y análisis de la Ley 1581 de 2012

Se invita a leer el documento Actividades de aplicación y análisis de la Ley 1581 de 2012 que se encuentra en la carpeta de anexos, donde se aborda el ámbito de aplicación, las definiciones fundamentales, las obligaciones de las organizaciones y las excepciones previstas en la Ley 1581 de 2012 mediante casos de análisis y una actividad práctica.

3. Principios rectores para el tratamiento de datos

Los principios rectores constituyen la base sobre la cual se desarrolla el sistema de protección de datos personales. Estos principios orientan las actuaciones de las organizaciones que recopilan, almacenan, utilizan, comparten o eliminan información personal, garantizando que el tratamiento de los datos se realice de manera responsable, transparente y respetuosa de los derechos de los titulares.

Su aplicación permite establecer criterios claros para la gestión de la información y facilita el cumplimiento de las obligaciones legales relacionadas con la protección de datos personales. Su observancia es obligatoria para todos los responsables y encargados del tratamiento, independientemente del tamaño o la naturaleza de la organización. Más allá de su carácter jurídico, estos principios promueven una cultura organizacional basada en la confianza, la transparencia y el respeto por la privacidad de las personas.

3.1. Principios relacionados con la legalidad

Los principios relacionados con la legalidad garantizan que el tratamiento de los datos personales se realice dentro del marco normativo vigente y con una finalidad claramente definida. Su aplicación evita prácticas arbitrarias o abusivas que puedan afectar los derechos de los titulares y exige que las organizaciones adopten procedimientos que permitan demostrar que la recolección y utilización de la información se desarrolla de forma legítima y conforme a la ley. Los principios relacionados con la legalidad se presentan a continuación:

- **Legalidad.** El tratamiento de datos personales es una actividad reglada que debe sujetarse a las disposiciones legales vigentes. Ninguna organización

puede recopilar, utilizar o compartir información personal sin fundamento legal. Este principio exige que las actividades relacionadas con el tratamiento de datos se desarrollen dentro de un marco jurídico que proteja los derechos de los titulares y que los procedimientos internos se encuentren documentados y alineados con la normativa aplicable.

- **Finalidad.** La recolección y el tratamiento de los datos personales deben responder a una finalidad legítima, específica y previamente informada al titular. La finalidad debe ser clara, verificable y coherente con las actividades de la organización. Los datos no pueden utilizarse para propósitos diferentes de aquellos para los cuales fueron recopilados, salvo que exista autorización del titular o una excepción prevista por la ley.
- **Libertad.** El tratamiento de los datos personales solo puede realizarse con el consentimiento previo, expreso e informado del titular. Este principio reconoce el derecho de las personas a decidir sobre el uso de su información y exige que la autorización pueda demostrarse mediante mecanismos que evidencien la aceptación voluntaria del titular. Asimismo, esta conserva el derecho de revocar la autorización cuando la normativa lo permita.

Cada uno de estos principios orienta decisiones y actuaciones específicas dentro de las organizaciones, garantizando que el tratamiento de los datos personales se ajuste a los requisitos legales y respete los derechos de los titulares.

Ejemplo:

Una empresa solicita información personal a sus clientes para registrar las garantías de sus productos. Antes de recopilar los datos, informa claramente la finalidad del tratamiento y obtiene la autorización correspondiente. De esta manera,

actúa conforme a los principios de legalidad, finalidad y libertad establecidos en la Ley 1581 de 2012. Los principales aspectos que deben considerarse para garantizar el cumplimiento del principio de finalidad son los siguientes:

- **Finalidad específica:** la información debe recopilarse para un propósito concreto y previamente definido.
- **Información al titular:** la finalidad debe comunicarse de manera clara antes de realizar el tratamiento de los datos.
- **Relación con la actividad de la organización:** el tratamiento debe responder a las funciones y actividades propias de la organización.
- **Prohibición de cambios arbitrarios:** los datos no pueden utilizarse para finalidades diferentes sin la autorización correspondiente o sin respaldo legal.
- **Trazabilidad:** la organización debe conservar evidencia que permita demostrar la finalidad para la cual fueron recopilados los datos personales.

Aplicación práctica

Cuando una organización implementa formularios físicos o digitales para recopilar datos personales, debe incorporar mecanismos que permitan obtener la autorización del titular, informar la finalidad del tratamiento y garantizar el cumplimiento de las disposiciones legales aplicables.

3.2. Principios relacionados con la calidad de la información

La calidad de la información constituye un elemento esencial para garantizar un tratamiento adecuado de los datos personales. La información debe mantenerse exacta, verificable, comprensible, actualizada y accesible para los titulares cuando ejerzan sus derechos.

La aplicación de estos principios permite que las organizaciones administren información confiable, reduzcan riesgos asociados con errores en los datos y garanticen que los titulares puedan conocer, actualizar o rectificar su información cuando sea necesario. Los principios relacionados con la calidad de la información se presentan a continuación:

- **Veracidad.** La información sujeta a tratamiento debe ser veraz, completa, exacta, actualizada, comprobable y comprensible. Mantener datos de calidad permite evitar decisiones erróneas, proteger los derechos de los titulares y fortalecer la eficiencia de los procesos organizacionales. Por ello, las organizaciones deben establecer mecanismos que faciliten la actualización, verificación y corrección permanente de la información.
- **Transparencia.** Garantiza el derecho de los titulares a conocer la existencia de sus datos personales y las condiciones bajo las cuales son tratados. Las organizaciones deben disponer de mecanismos que permitan consultar la información almacenada, identificar las finalidades del tratamiento y conocer quiénes tienen acceso a ella. Este principio fortalece la confianza y favorece el cumplimiento de las obligaciones legales relacionadas con el tratamiento de datos personales.
- **Acceso y circulación restringida.** Los datos personales solo pueden ser consultados por personas autorizadas y utilizados para las finalidades previamente informadas al titular. La información no debe encontrarse disponible para cualquier persona ni divulgarse indiscriminadamente. Su aplicación exige controles de acceso, mecanismos de autenticación y

medidas de seguridad que protejan la confidencialidad de la información y reduzcan el riesgo de accesos no autorizados.

La aplicación conjunta de estos principios contribuye a garantizar la calidad de la información, fortalecer la confianza de los titulares y reducir los riesgos derivados del tratamiento inadecuado de los datos personales.

Ejemplo:

Una entidad financiera mantiene desactualizada la dirección de un cliente y envía comunicaciones a una ubicación incorrecta. Esta situación evidencia la importancia de verificar periódicamente la exactitud de la información y de implementar mecanismos que permitan mantener los datos actualizados durante todo su ciclo de vida. Los principales beneficios de garantizar la veracidad de la información son los siguientes:

- **Mejora de la calidad de los procesos:** favorece la confiabilidad y consistencia de la información utilizada por la organización.
- **Reducción de errores administrativos:** disminuye inconsistencias, reprocesos y errores derivados de datos incorrectos o desactualizados.
- **Apoyo a la toma de decisiones:** facilita la adopción de decisiones fundamentadas en información precisa, completa y actualizada.
- **Fortalecimiento de la confianza de los titulares:** incrementa la credibilidad de la organización mediante un tratamiento responsable de los datos personales.
- **Disminución de riesgos operativos:** reduce la probabilidad de incidentes asociados al uso de información inexacta, incompleta o desactualizada.

3.3. Principios relacionados con la protección de la información

La protección de los datos personales requiere la implementación de medidas que garanticen la confidencialidad, la integridad y la disponibilidad de la información durante todo su ciclo de vida. Estos principios orientan a las organizaciones en la adopción de controles que permitan prevenir incidentes de seguridad y proteger los derechos de los titulares.

Su aplicación fortalece la gestión de la información, disminuye los riesgos asociados con el tratamiento de los datos personales y contribuye al cumplimiento de las obligaciones establecidas en la Ley 1581 de 2012. Los principios relacionados con la protección de la información se presentan a continuación:

- **Seguridad.** Las organizaciones deben adoptar medidas técnicas, humanas y administrativas que protejan los datos personales frente a riesgos de pérdida, alteración, acceso no autorizado, destrucción o uso fraudulento. La seguridad de la información no depende únicamente de herramientas tecnológicas; también comprende la capacitación del personal, la definición de procedimientos, la gestión de riesgos y la implementación de controles organizacionales que garanticen la protección de los datos durante todo su ciclo de vida.
- **Confidencialidad.** Todas las personas que intervienen en el tratamiento de datos personales tienen el deber de garantizar la reserva de la información, incluso después de finalizar su relación con la organización. Este principio impide que los datos sean divulgados o utilizados por personas no autorizadas y resulta especialmente relevante en sectores como salud,

educación, servicios financieros y gestión del talento humano, donde se administra información sensible o de carácter reservado.

- **Aplicación de los principios.** La protección efectiva de los datos personales requiere incorporar los principios rectores en las políticas, procedimientos y procesos institucionales. Cada actividad relacionada con la recolección, el almacenamiento, el uso, la circulación, la conservación y la supresión de la información debe desarrollarse conforme a los principios de legalidad, finalidad, libertad, veracidad, transparencia, acceso y circulación restringida, seguridad y confidencialidad. Su aplicación integral fortalece la protección de la información, reduce riesgos legales y operativos y consolida la confianza de los grupos de interés.

La implementación de estos principios debe complementarse con medidas de seguridad acordes con la naturaleza de la información y con los riesgos identificados por cada organización. Las principales medidas para fortalecer la seguridad de la información son las siguientes:

- **Contraseñas seguras.** Proteger el acceso a los sistemas de información mediante mecanismos de autenticación confiables.
- **Control de accesos.** Limitar el acceso a la información únicamente al personal autorizado.
- **Copias de respaldo.** Garantizar la recuperación de la información ante incidentes o pérdidas de datos.
- **Cifrado de la información.** Proteger los datos durante su almacenamiento y transmisión.

- **Monitoreo de sistemas.** Detectar oportunamente accesos no autorizados, incidentes y vulnerabilidades.
- **Capacitación del personal.** Fortalecer las competencias del personal para prevenir riesgos y aplicar buenas prácticas de seguridad.

Ejemplo:

Una entidad financiera mantiene desactualizada la dirección de un cliente y envía comunicaciones a una ubicación incorrecta. Esta situación evidencia la importancia de verificar periódicamente la exactitud de la información y de implementar mecanismos que permitan mantener los datos actualizados durante todo su ciclo de vida. Los principales beneficios de garantizar la veracidad de la información son los siguientes:

- **Acuerdos de confidencialidad:** formalizar el compromiso de proteger la información personal a la que se tiene acceso durante el desarrollo de las funciones.
- **Limitación de accesos según funciones:** garantizar que cada persona acceda únicamente a los datos necesarios para el cumplimiento de sus responsabilidades.
- **Capacitación del personal:** fortalecer el conocimiento sobre las obligaciones, responsabilidades y buenas prácticas en materia de protección de datos personales.
- **Supervisión del uso de la información:** verificar el cumplimiento de las políticas de tratamiento de datos y detectar oportunamente posibles incumplimientos.

- **Aplicación de controles disciplinarios:** establecer medidas correctivas frente a conductas que comprometan la seguridad, la confidencialidad o el adecuado tratamiento de la información.

Actividades de aplicación y análisis de los principios rectores para el tratamiento de datos personales

Se invita a leer el documento Actividades de aplicación y análisis de los principios rectores para el tratamiento de datos personales que se encuentra en la carpeta de anexos, donde se aborda la aplicación práctica de los principios rectores establecidos en la Ley 1581 de 2012 mediante casos de análisis, ejemplos organizacionales y actividades de integración.

4. Categorías especiales de datos personales

La protección de datos personales exige reconocer que no toda la información tiene el mismo nivel de sensibilidad, exposición o riesgo. Algunos datos pueden consultarse en fuentes públicas; otros requieren autorización para ser utilizados y algunos demandan medidas especiales de protección, debido a que pueden afectar la intimidad, la seguridad, la dignidad o los derechos fundamentales de una persona.

La clasificación de los datos personales permite a las organizaciones identificar el tipo de información que administran, determinar el nivel de protección que requiere cada categoría y definir los controles necesarios para prevenir usos indebidos. Asimismo, facilita la asignación de responsabilidades, la gestión de permisos de acceso, la implementación de mecanismos de almacenamiento, la definición de tiempos de conservación y la atención de las solicitudes presentadas por los titulares.

En el contexto organizacional, clasificar correctamente los datos constituye una actividad esencial para cumplir la normativa. No es equivalente tratar datos de contacto de un cliente que administrar historias clínicas, información financiera, datos biométricos o información de niños, niñas y adolescentes. Cada categoría requiere un tratamiento proporcional al nivel de riesgo que representa.

Además, esta clasificación facilita la elaboración de políticas de tratamiento de datos personales, inventarios de bases de datos, matrices de riesgos y controles de seguridad. Por ello, antes de recopilar información, la organización debe identificar qué datos necesita, con qué finalidad los utilizará, quién podrá acceder a ellos y cuáles serán las medidas implementadas para garantizar su protección.

4.1. Clasificación de los datos personales

La clasificación de los datos personales consiste en organizar la información de acuerdo con su naturaleza, nivel de acceso, grado de sensibilidad y posible impacto sobre los derechos del titular. Este proceso permite diferenciar los datos que pueden consultarse públicamente de aquellos que requieren reserva o un nivel reforzado de protección.

En las organizaciones, esta clasificación debe aplicarse desde el diseño de formularios, bases de datos, sistemas de información, procesos de selección, registros de clientes, expedientes laborales, historias clínicas, plataformas educativas y cualquier otro mecanismo mediante el cual se recopilen datos personales.

Una adecuada clasificación evita tratar toda la información como si fuera pública o, por el contrario, aplicar restricciones innecesarias a datos que presentan un bajo nivel de riesgo. En consecuencia, las medidas de protección deben ser proporcionales a la naturaleza del dato y al riesgo asociado. Los principales tipos de datos personales se relacionan a continuación:

Datos públicos

Corresponden a información que no tiene carácter reservado y que puede ser conocida por terceros conforme a la ley. Aunque su acceso es permitido, su tratamiento debe respetar los principios de legalidad, finalidad, transparencia y seguridad.

- **Ejemplo.** Estado civil, profesión u oficio, calidad de comerciante, información contenida en documentos públicos, registros mercantiles y demás fuentes públicas autorizadas.

- **Medidas o consideraciones** Deben utilizarse únicamente para finalidades legítimas. Se recomienda documentar la fuente consultada, la finalidad del tratamiento y el responsable de la consulta.

Datos privados

Son aquellos que solo interesan al titular o a un grupo limitado de personas autorizadas. Su divulgación puede afectar la privacidad, la seguridad, la situación económica o la vida laboral del titular.

- **Ejemplo.** Información salarial, datos familiares, información financiera, información tributaria, evaluaciones de desempeño, expedientes laborales e información contractual.
- **Medidas o consideraciones.** Requieren controles estrictos de acceso, almacenamiento seguro, políticas internas de protección y mecanismos que prevengan pérdidas, alteraciones o divulgaciones no autorizadas.

Datos semiprivados

Son datos cuyo conocimiento puede interesar a un sector determinado o a personas autorizadas para una finalidad legítima. No pertenecen al ámbito íntimo del titular, pero tampoco son de libre consulta.

- **Ejemplo.** Historial crediticio, comportamiento financiero, información comercial y comportamiento económico.
- **Medidas o consideraciones.** Su consulta debe responder a una finalidad legítima y, cuando corresponda, contar con la autorización del titular o con habilitación legal. Es recomendable registrar las consultas realizadas y verificar la pertinencia del tratamiento.

La correcta clasificación de la información permite establecer controles diferenciados para cada categoría de datos personales y fortalece el cumplimiento de las obligaciones establecidas en la Ley 1581 de 2012.

Ejemplo:

Una empresa consulta el registro mercantil de un proveedor antes de iniciar un proceso de contratación. La información corresponde a datos públicos y se utiliza para verificar la existencia legal del proveedor dentro de una finalidad legítima relacionada con el proceso contractual. Por su parte, el área de talento humano administra hojas de vida, contratos, evaluaciones de desempeño, incapacidades y datos familiares de los trabajadores. Esta información corresponde a datos privados y debe conservarse con medidas de seguridad que limiten su consulta al personal autorizado. De igual forma, una entidad financiera consulta el historial crediticio de una persona que solicita un préstamo. En este caso, la información corresponde a datos semiprivados y su tratamiento debe realizarse conforme a las condiciones legales aplicables y a la finalidad relacionada con la evaluación del riesgo crediticio.

Aplicación práctica

Para gestionar adecuadamente las diferentes categorías de datos personales, las organizaciones pueden implementar procedimientos que permitan identificar el tipo de información recopilada, definir quién puede acceder a ella, establecer la finalidad del tratamiento y documentar las evidencias de las consultas realizadas. Estas acciones fortalecen el cumplimiento normativo y reducen los riesgos asociados con el tratamiento de la información.

4.2. Datos sensibles

Los datos sensibles constituyen una categoría especial dentro de la protección de datos personales. Corresponden a información que puede afectar la intimidad del titular o cuyo uso indebido puede generar discriminación, exclusión, afectaciones laborales, daño moral, vulneración de la dignidad humana o riesgos para la seguridad personal.

Debido a su naturaleza, estos datos requieren un nivel de protección superior al de las demás categorías de información. Su tratamiento solo puede realizarse cuando exista una finalidad legítima, una autorización válida o una de las excepciones previstas en la ley, además de medidas de seguridad acordes con el nivel de riesgo. En el contexto organizacional, los datos sensibles pueden estar presentes en procesos de seguridad y salud en el trabajo, historias clínicas, controles biométricos, programas de bienestar, investigaciones internas, procesos educativos y demás actividades que impliquen el tratamiento de información especialmente protegida.

La adecuada gestión de estos datos exige aplicar controles específicos durante todo su ciclo de vida, ya que una falla en su tratamiento puede generar consecuencias para los titulares y responsabilidades legales para la organización. Los principales aspectos relacionados con el tratamiento de datos sensibles se presentan a continuación:

- **Concepto y características.** Los datos sensibles corresponden a información relacionada con aspectos íntimos o especialmente protegidos de una persona, como el origen racial o étnico, la orientación política, las convicciones religiosas o filosóficas, la afiliación sindical, la información sobre salud, los datos biométricos y la información relativa a la vida sexual. Su

tratamiento exige protección reforzada, autorización expresa, una finalidad específica, acceso restringido y la aplicación del principio de necesidad, evitando solicitar este tipo de información cuando no resulte indispensable para cumplir la finalidad prevista.

- **Restricciones para su tratamiento.** Como regla general, ninguna persona está obligada a suministrar datos sensibles. Antes de su recolección, la organización debe informar al titular que se trata de información especialmente protegida, explicar claramente la finalidad del tratamiento, indicar el carácter facultativo de la entrega de la información cuando corresponda y obtener una autorización expresa. Además, el acceso debe limitarse al personal autorizado y cualquier comunicación a terceros debe realizarse conforme a las condiciones establecidas por la ley.
- **Medidas de protección.** La protección de los datos sensibles requiere medidas técnicas, administrativas y organizacionales. Estas incluyen controles de acceso, cifrado de la información, autenticación multifactor, copias de respaldo, acuerdos de confidencialidad, capacitación del personal, definición de responsables, matrices de permisos, auditorías internas y protocolos para la atención de incidentes. La combinación de estas medidas fortalece la seguridad de la información y reduce la probabilidad de accesos no autorizados o divulgaciones indebidas.

Las principales características de los datos sensibles se relacionan a continuación:

- **Protección reforzada.** Requieren medidas de seguridad más estrictas que las aplicadas a otros datos personales.

- **Riesgo de discriminación.** Su uso indebido puede afectar la igualdad, la dignidad y otros derechos fundamentales del titular.
- **Autorización expresa.** El titular debe aceptar de manera libre, previa, expresa e informada el tratamiento de la información, salvo las excepciones legales.
- **Finalidad específica.** Solo pueden recopilarse cuando exista una necesidad legítima y claramente definida.
- **Acceso restringido.** Deben ser consultados únicamente por personas autorizadas para el cumplimiento de sus funciones.

Ejemplo:

Una clínica administra historias clínicas que contienen diagnósticos, tratamientos, antecedentes médicos y resultados de exámenes. Debido a la naturaleza de esta información, debe implementar controles reforzados que garanticen la confidencialidad, la integridad y la disponibilidad de los datos. Otro ejemplo corresponde a una empresa que utiliza la huella dactilar para controlar el ingreso de sus trabajadores. Al tratarse de un dato biométrico, la organización debe justificar su utilización, obtener la autorización correspondiente e implementar medidas técnicas y administrativas que garanticen su protección.

Los principales requisitos para el tratamiento de datos sensibles son los siguientes:

- **Informar la naturaleza sensible del dato:** comunicar al titular que la información corresponde a un dato sensible y requiere un nivel especial de protección.

- **Explicar la finalidad:** informar de manera clara para qué se solicita la información y cómo será utilizada durante su tratamiento.
- **Obtener autorización expresa:** conservar evidencia de la autorización libre, previa, expresa e informada del titular, cuando la normativa lo exija.
- **Limitar la recolección:** solicitar únicamente los datos sensibles que sean estrictamente necesarios para cumplir la finalidad prevista.
- **Proteger el acceso:** restringir el acceso a la información sensible exclusivamente al personal autorizado mediante controles de seguridad adecuados.

Ejemplo organizacional

Una empresa solicita información sobre las condiciones médicas de sus trabajadores para desarrollar actividades de seguridad y salud en el trabajo. Antes de recopilar esta información, informa la finalidad del tratamiento, limita el acceso al personal competente y adopta medidas de seguridad para proteger los documentos físicos y digitales donde se almacena la información. Las principales medidas para fortalecer la protección de los datos sensibles se presentan a continuación:

Tabla 2. Medidas de protección para el tratamiento seguro de datos personales sensibles

Tipo de medida	Ejemplo	Propósito
Técnica	Cifrado de bases de datos.	Proteger la información frente a accesos no autorizados.
Administrativa	Acuerdos de confidencialidad.	Fortalecer el compromiso del personal con la reserva de la información.

Tipo de medida	Ejemplo	Propósito
Organizacional	Matriz de permisos.	Definir quién puede consultar, modificar o administrar los datos sensibles.
Preventiva	Capacitación al personal.	Reducir errores humanos durante el tratamiento de la información.
Correctiva	Protocolo para la atención de incidentes.	Responder oportunamente ante vulneraciones de seguridad.

4.3. Datos de niños, niñas y adolescentes

Los datos personales de niños, niñas y adolescentes cuentan con una protección especial, debido a que sus titulares se encuentran en una condición que exige mayores garantías para la protección de sus derechos. En consecuencia, cualquier tratamiento de esta información debe orientarse por el principio del interés superior del menor y por el respeto de sus derechos fundamentales.

Las organizaciones que administran información de menores de edad, como instituciones educativas, entidades deportivas, fundaciones, plataformas tecnológicas, programas sociales, entidades de salud y organizaciones recreativas, deben actuar con especial diligencia durante la recolección, el uso, el almacenamiento, la circulación y la eliminación de estos datos.

El tratamiento de esta información no debe limitarse al cumplimiento de requisitos administrativos. También debe considerar los riesgos derivados de la posible exposición de fotografías, información académica, datos familiares, información médica, datos de ubicación o cualquier otro dato que pueda comprometer la seguridad, la intimidad o el desarrollo integral del menor.

Por esta razón, las organizaciones deben establecer procedimientos específicos para garantizar un tratamiento seguro, proporcional y conforme con la normativa vigente. Los principales aspectos relacionados con el tratamiento de datos personales de niños, niñas y adolescentes se presentan a continuación:

- **Protección especial.** La protección de los datos personales de niños, niñas y adolescentes tiene como finalidad garantizar su desarrollo integral, su dignidad, su seguridad y el ejercicio pleno de sus derechos. Toda decisión relacionada con el tratamiento de esta información debe responder al principio del interés superior del menor, evitando cualquier uso que pueda generar exposición, discriminación, afectaciones a la intimidad o riesgos para su integridad.
- **Requisitos para el tratamiento.** El tratamiento debe responder a una finalidad legítima y necesaria, contar con la autorización del representante legal cuando sea exigible, aplicar medidas de seguridad apropiadas y limitar la recolección únicamente a los datos indispensables para cumplir la finalidad prevista. Además, la organización debe garantizar que la información permanezca protegida durante todo su ciclo de vida.
- **Casos de aplicación.** Los datos de niños, niñas y adolescentes se tratan en diferentes contextos, como instituciones educativas, escuelas deportivas, plataformas digitales y programas sociales. En todos los casos, la organización debe evaluar el tipo de información tratada, los riesgos asociados, los permisos de acceso, las autorizaciones obtenidas y las medidas de protección implementadas para garantizar el respeto de los derechos de los menores.

Las principales situaciones que requieren una protección especial se relacionan a continuación:

Tabla 3. Riesgos y medidas de protección en el tratamiento de datos personales en el ámbito educativo

Situación	Riesgo principal	Medida recomendada
Publicación de fotografías de menores.	Uso no autorizado de la imagen.	Obtener autorización previa y definir claramente la finalidad del tratamiento.
Compartir listados de estudiantes.	Exposición de datos personales.	Restringir el acceso y utilizar canales institucionales seguros.
Almacenamiento de datos médicos escolares.	Divulgación de datos sensibles.	Aplicar medidas de protección reforzada y limitar el acceso al personal autorizado.
Uso de plataformas educativas.	Acceso no autorizado a la información.	Configurar adecuadamente los permisos de acceso y administrar los usuarios de forma segura.

Ejemplo

Una institución educativa toma fotografías durante una actividad académica y desea publicarlas en sus medios institucionales. Antes de hacerlo, debe verificar que cuenta con la autorización correspondiente, que existe una finalidad legítima para el tratamiento y que la publicación no expone innecesariamente a los estudiantes. Los principales requisitos para el tratamiento de datos personales de menores de edad son los siguientes:

- **Finalidad legítima:** verificar que la información del menor se recopile para un propósito específico, legítimo y relacionado con las actividades de la organización.
- **Necesidad:** confirmar que los datos solicitados sean indispensables para cumplir la finalidad prevista.
- **Autorización:** verificar que se cuente con la autorización válida del representante legal, cuando sea exigible.
- **Seguridad:** garantizar que la información se almacene, consulte y proteja mediante controles de seguridad adecuados.
- **Proporcionalidad:** asegurar que únicamente se recopilen los datos personales estrictamente necesarios para la finalidad definida.

Aplicación práctica

Al revisar un formulario de inscripción dirigido a menores de edad, la organización debe verificar que cada dato solicitado tenga una finalidad claramente justificada. Cuando un dato no resulte necesario para la prestación del servicio o el desarrollo de la actividad, debe eliminarse del formulario o justificarse técnicamente su necesidad. Los principales entornos en los que se realiza el tratamiento de datos personales de niños, niñas y adolescentes son los siguientes:

Tabla 4. Tratamiento de datos personales en diferentes entornos y controles de protección

Situación	Datos tratados	Riesgo principal	Control recomendado
Institución educativa	Calificaciones, asistencia y datos familiares.	Exposición de información académica o familiar.	Acceso por roles y utilización de canales institucionales.

Situación	Datos tratados	Riesgo principal	Control recomendado
Escuela deportiva	Datos de salud, acudientes y fotografías.	Uso indebido de la imagen o de la información médica.	Autorizaciones previas y almacenamiento seguro.
Plataforma digital	Usuario, correo electrónico y actividad en línea.	Acceso no autorizado o exposición digital.	Configuración de privacidad, autenticación y monitoreo.
Programa social	Caracterización familiar y datos de contacto.	Divulgación indebida o estigmatización.	Reserva documental y tratamiento conforme a la finalidad declarada.

Actividades de aplicación y análisis de las categorías especiales de datos personales

Se invita a leer el documento Actividades de aplicación y análisis de las categorías especiales de datos personales que se encuentra en la carpeta de anexos, donde se aborda la clasificación de los datos personales, el tratamiento de datos sensibles y de niños, niñas y adolescentes, así como las medidas de protección exigidas por la Ley 1581 de 2012.

5. Derechos y condiciones de legalidad para el tratamiento de datos

El tratamiento de datos personales no se limita a la recolección, el almacenamiento o el uso de la información. También implica garantizar que los titulares puedan ejercer control sobre sus datos y que las organizaciones actúen bajo condiciones legales claras, verificables y respetuosas de los derechos fundamentales. En este sentido, la Ley 1581 de 2012 desarrolla el derecho de las personas a conocer, actualizar, rectificar y, cuando corresponda, solicitar la supresión de la información recopilada sobre ellas en bases de datos o archivos.

En el contexto organizacional, el cumplimiento de estas condiciones va más allá de disponer de un aviso de privacidad o de una autorización firmada. También exige demostrar que la información se recopila para finalidades legítimas, que el titular conoce el uso de sus datos, que existen mecanismos para atender consultas y reclamaciones y que se aplican medidas de seguridad durante todo el ciclo de vida de la información.

El desconocimiento de los derechos de los titulares o el tratamiento de datos sin cumplir los requisitos legales puede generar reclamaciones, investigaciones administrativas, sanciones, pérdida de confianza y afectaciones reputacionales. Por ello, las organizaciones deben implementar procedimientos que garanticen el ejercicio efectivo de estos derechos.

5.1. Derechos de los titulares

Los titulares son las personas naturales a quienes pertenecen los datos personales. La normativa les reconoce un conjunto de derechos que les permite mantener el control sobre la información suministrada a entidades públicas, empresas

privadas, instituciones educativas, prestadores de servicios, plataformas digitales y demás organizaciones que realizan tratamiento de datos personales.

El ejercicio de estos derechos exige que las organizaciones cuenten con canales de atención, procedimientos internos, responsables definidos y tiempos de respuesta que permitan atender oportunamente las solicitudes de los titulares. Los principales derechos reconocidos por la Ley 1581 de 2012 se presentan a continuación:

Conocer la información

Permite al titular conocer qué datos personales conserva la organización, las finalidades del tratamiento, el uso de la información y, cuando corresponda, los terceros con quienes ha sido compartida.

Ejemplo de aplicación

Solicitar copia de la información registrada en una base de datos de clientes.

Actualizar y rectificar datos

Permite solicitar la actualización o corrección de información incompleta, inexacta, desactualizada o errónea para garantizar la calidad de los datos personales.

Ejemplo de aplicación

Modificar el número telefónico, la dirección, el correo electrónico o corregir un documento de identidad registrado de forma incorrecta.

Suprimir información

Permite solicitar la eliminación de los datos personales cuando no exista una finalidad legítima para conservarlos o cuando su tratamiento no se ajuste a la normativa.

Ejemplo de aplicación

Solicitar el retiro de los datos de una base utilizada para campañas comerciales.

Revocar la autorización

Permite retirar el consentimiento previamente otorgado para el tratamiento de los datos personales, cuando ello sea procedente conforme a la ley.

Ejemplo de aplicación

Solicitar que la organización deje de enviar comunicaciones promocionales.

La aplicación de estos derechos fortalece la transparencia, favorece el cumplimiento de la normativa y promueve una relación de confianza entre los titulares y las organizaciones. Los principales aspectos relacionados con el ejercicio de estos derechos se presentan a continuación:

Conocer la información

El titular puede solicitar información sobre los datos personales que conserva la organización, las finalidades del tratamiento, el uso de la información y los terceros con quienes ha sido compartida, cuando corresponda. Para garantizar este derecho, la organización debe disponer de canales físicos o digitales que permitan atender las consultas de manera clara, verificable y oportuna.

Aspectos relevantes

Favorece la transparencia y permite al titular ejercer control sobre su información personal.

Actualizar y rectificar datos

El titular puede solicitar la corrección de datos incompletos, inexactos, desactualizados o erróneos. La organización debe verificar la identidad del solicitante, validar la información suministrada y realizar las actualizaciones en todos los sistemas donde los datos se encuentren registrados.

Aspectos relevantes

Garantiza la calidad de la información y evita errores que puedan afectar decisiones administrativas, comerciales o legales.

Suprimir información

El titular puede solicitar la eliminación de sus datos personales cuando ya no sean necesarios para la finalidad autorizada o cuando el tratamiento no se ajuste a la normativa. Antes de atender la solicitud, la organización debe verificar si existen obligaciones legales o contractuales que exijan conservar la información.

Aspectos relevantes

La supresión puede implicar la eliminación, el bloqueo, la anonimización o la restricción del uso de los datos, según cada caso.

Para atender adecuadamente el derecho a conocer la información, las organizaciones deben estar en capacidad de suministrar, como mínimo, la siguiente información:

- **Datos personales almacenados.** Información registrada en las bases de datos institucionales.
- **Finalidad del tratamiento.** Motivo por el cual fueron recopilados y son utilizados los datos.

- **Autorización otorgada.** Evidencia del consentimiento del titular, cuando sea exigible.
- **Uso de la información.** Procesos o actividades en los que se emplean los datos personales.
- **Canales de atención.** Medios habilitados para consultas, reclamaciones o ejercicio de derechos.

Ejemplo:

Una persona solicita a una empresa de servicios públicos conocer los datos personales que conserva sobre ella. La organización verifica la identidad del solicitante, consulta sus bases de datos y suministra información sobre los datos registrados, las finalidades del tratamiento y los canales disponibles para ejercer los demás derechos reconocidos por la Ley 1581 de 2012.

Aplicación práctica

Las respuestas a las consultas de los titulares deben ser específicas, verificables y relacionadas con la información solicitada. Respuestas generales o ambiguas no garantizan el ejercicio efectivo del derecho a conocer la información ni evidencian el cumplimiento del principio de transparencia. Las situaciones más frecuentes relacionadas con el derecho de actualización y rectificación se presentan a continuación:

Tabla 5. Riesgos y acciones para la actualización y corrección de datos personales

Situación	Riesgo si no se corrige	Acción recomendada
Correo electrónico desactualizado	Pérdida de comunicaciones importantes.	Actualizar la información en todos los sistemas relacionados.
Número de documento incorrecto	Errores en trámites y registros.	Verificar el soporte documental y corregir la información.
Dirección física equivocada	Envío de información a personas no autorizadas.	Validar el nuevo dato y actualizar todas las bases correspondientes.
Información laboral incompleta	Decisiones administrativas erróneas.	Completar y verificar el expediente con los soportes respectivos.

5.2. Autorización para el tratamiento de datos

La autorización es la manifestación de voluntad mediante la cual el titular permite que sus datos personales sean tratados para una o varias finalidades determinadas. Constituye una de las principales condiciones de legalidad previstas en la Ley 1581 de 2012 y representa una garantía tanto para el titular como para la organización que realiza el tratamiento.

Para que la autorización sea válida, debe obtenerse antes del tratamiento de los datos, expresar de manera clara la aceptación del titular y suministrar información suficiente sobre la finalidad del tratamiento, los derechos que puede ejercer y los canales disponibles para presentar consultas o reclamaciones.

La autorización no debe entenderse como un requisito meramente documental. Además de obtenerla correctamente, la organización debe conservar la evidencia que

demuestre su existencia y garantizar que pueda consultarse cuando sea requerida por el titular o por las autoridades competentes.

A continuación, se presenta un pódcast sobre la autorización para el tratamiento de datos personales, en el que se describen sus elementos, características, los medios para obtenerla y la importancia de conservar las evidencias que demuestran el consentimiento otorgado por el titular.

Transcripción del pódcast. Autorización para el tratamiento de datos personales

Mujer: Cada vez que llenamos un formulario, hacemos una compra por internet o marcamos una casilla de “Acepto”, también estamos dando permiso para usar nuestra información personal.

Hombre: Todo ocurre en cuestión de segundos. Marcamos la casilla, aceptamos y seguimos adelante, casi sin pensar qué información acabamos de compartir.

Mujer: Ese permiso se llama autorización para el tratamiento de datos personales. Significa aceptar que nuestra información sea utilizada para una finalidad específica.

Hombre: La decisión debe tomarse con toda la información sobre la mesa. Y la organización debe poder demostrar que ese consentimiento fue realmente libre.

Ese consentimiento puede quedar registrado en un formulario, una firma digital, una grabación telefónica o una casilla de aceptación. Después debe ser posible comprobar que realmente existió.

Transcripción del podcast. Autorización para el tratamiento de datos personales

Mujer: Cada persona debe saber exactamente qué está autorizando. Por eso la autorización debe explicar para qué se van a usar los datos, cuáles serán tratados, qué derechos conserva el titular y cómo puede ejercerlos.

Hombre: La información debe presentarse de forma clara para que la decisión sea consciente.

Mujer: La autorización debe obtenerse antes de utilizar los datos y explicar con claridad qué información será tratada, para qué se va a usar y dejar evidencia de que la persona aceptó esa decisión.

Hombre: La organización debe estar en capacidad de demostrar que ese consentimiento sí existió.

Mujer: Conservar esas evidencias también hace parte del proceso. Documentos físicos, registros electrónicos, grabaciones o correos pueden convertirse en el respaldo de esa autorización.

Hombre: Esos soportes permiten identificar quién autorizó el tratamiento, cuándo lo hizo, con qué finalidad y mediante qué mecanismo otorgó su consentimiento.

Mujer: Un consentimiento claro protege a las organizaciones y a las personas, además de fortalecer la confianza entre ambas.

Transcripción del pódcast. Autorización para el tratamiento de datos personales

Una decisión informada siempre ofrece más tranquilidad. Vale la pena dedicar unos segundos a leer, comprender y decidir conscientemente antes de compartir nuestros datos personales.

Los elementos mínimos que debe contener una autorización se relacionan a continuación:

- **Identificación del titular.** Permite asociar la autorización con una persona determinada.
- **Finalidad del tratamiento.** Explica para qué serán utilizados los datos personales.
- **Datos objeto del tratamiento.** Indica la información que será recopilada o utilizada.
- **Derechos del titular.** Informa los derechos que puede ejercer conforme a la Ley 1581 de 2012.
- **Canales de atención.** Señala los medios disponibles para consultas, reclamos y solicitudes.
- **Evidencia de la autorización.** Permite demostrar que el titular otorgó su consentimiento.

Las características que debe reunir una autorización válida son las siguientes:

Tabla 6. Características de la autorización para el tratamiento de datos personales

Característica	Significado	Ejemplo
Previa	Se obtiene antes de iniciar el tratamiento de los datos personales.	Solicitar la aceptación antes de registrar la información en un formulario.
Expresa	Existe una manifestación clara e inequívoca del titular.	Firma, casilla de aceptación voluntaria o confirmación verificable.
Informada	El titular conoce la finalidad, los derechos y las condiciones del tratamiento.	Aviso de privacidad presentado antes de solicitar la autorización.
Verificable	Puede demostrarse posteriormente mediante evidencias.	Registro físico o electrónico conservado por la organización.

Ejemplo:

Una empresa de capacitación recopila datos de personas interesadas en un curso. Antes de registrar la información, presenta un aviso en el que informa que los datos serán utilizados para gestionar la inscripción, establecer contacto con el participante y enviar información relacionada con la actividad académica. Posteriormente, solicita la aceptación mediante una casilla de consentimiento que el usuario debe seleccionar de manera voluntaria. Los principales medios para obtener la autorización son los siguientes:

- **Formato físico:** utilizado en inscripciones, contratos y trámites presenciales. La evidencia recomendada es el documento firmado y debidamente archivado.
- **Formulario web:** empleado para el registro en plataformas y servicios digitales. La evidencia debe incluir la fecha, la hora, la dirección IP, el usuario y el texto de la autorización aceptada.

- **Grabación telefónica:** utilizada en procesos de ventas o atención mediante llamadas. La evidencia consiste en el archivo de audio asociado al titular.
- **Correo electrónico:** empleado para confirmaciones o solicitudes específicas. La evidencia corresponde al mensaje completo y a la trazabilidad de su envío y recepción.
- **Firma electrónica o digital:** utilizada en procesos electrónicos formales. La evidencia incluye el certificado, el registro o el documento firmado electrónicamente.

Aplicación práctica Al seleccionar el mecanismo para obtener la autorización, la organización debe considerar el tipo de información que será tratada y el nivel de riesgo asociado. Para datos básicos puede ser suficiente un formulario claro y verificable; en el caso de datos sensibles, es recomendable utilizar mecanismos de autenticación y conservación de evidencias que ofrezcan mayores garantías de seguridad y trazabilidad.

Las principales evidencias que permiten demostrar la autorización se presentan a continuación:

- **Formato firmado.** Nombre del titular, fecha, finalidad, firma y versión del documento.
- **Registro web.** Usuario, fecha, hora, dirección IP, finalidad aceptada y evidencia del consentimiento.
- **Grabación.** Identificación del titular, información suministrada y aceptación manifestada.
- **Correo electrónico.** Mensaje enviado, respuesta del titular y trazabilidad de la comunicación.

- **Contrato.** Cláusula de tratamiento de datos, aceptación y fecha de suscripción.

5.3. Condiciones de legalidad

Las condiciones de legalidad corresponden a los requisitos que permiten determinar si el tratamiento de datos personales se realiza conforme a la Ley 1581 de 2012 y a las demás disposiciones aplicables. Estas condiciones garantizan que la recolección, el uso, el almacenamiento, la circulación, la conservación y la supresión de la información respeten los derechos de los titulares y respondan a una finalidad legítima.

Una organización puede disponer de procesos bien estructurados y herramientas tecnológicas avanzadas; sin embargo, si recopila información sin autorización, la utiliza para finalidades diferentes a las informadas o no garantiza el ejercicio de los derechos de los titulares, el tratamiento puede resultar contrario a la normativa.

- **Condiciones de legalidad.** El tratamiento de datos personales debe sustentarse en una finalidad legítima, contar con la autorización cuando sea exigible, informar previamente al titular sobre el tratamiento, aplicar el principio de proporcionalidad, proteger la información mediante medidas de seguridad y garantizar canales para el ejercicio de los derechos de los titulares.
- **Tratamiento autorizado.** Existe cuando la organización cuenta con una base legal válida para tratar los datos personales y respeta los límites de la autorización otorgada por el titular. El uso de la información debe ser

coherente con la finalidad informada y respaldarse mediante evidencias que permitan demostrar el cumplimiento de la normativa.

- **Tratamiento sin autorización.** Se presenta cuando la organización recopila, utiliza, conserva o comparte datos personales sin autorización del titular o sin otra condición legal que habilite el tratamiento. También ocurre cuando los datos se utilizan para finalidades diferentes de aquellas informadas inicialmente.
- **Consecuencias del incumplimiento.** El incumplimiento de las condiciones de legalidad puede generar investigaciones administrativas, sanciones, pérdidas económicas, afectaciones reputacionales, interrupciones operativas y vulneraciones de los derechos de los titulares.

Las principales condiciones que deben verificarse antes de realizar el tratamiento de datos personales son las siguientes:

- **Finalidad legítima.** ¿Existe una razón clara, específica y válida para tratar los datos personales?
- **Autorización.** ¿El titular otorgó autorización cuando la normativa lo exige?
- **Información previa.** ¿El titular recibió información suficiente sobre el tratamiento de sus datos?
- **Proporcionalidad.** ¿Solo se recopilan los datos estrictamente necesarios para la finalidad prevista?
- **Seguridad.** ¿La información cuenta con medidas de protección adecuadas?
- **Atención de derechos.** ¿La organización dispone de canales para atender consultas, reclamos y solicitudes?

La aplicación de estas condiciones permite demostrar que el tratamiento de los datos personales se desarrolla conforme a los principios de legalidad, finalidad, transparencia y responsabilidad. Los elementos que caracterizan un tratamiento autorizado se presentan a continuación:

- **Finalidad:** definir un propósito claro, específico y conocido por el titular antes de realizar el tratamiento de los datos personales.
- **Autorización:** obtener y conservar una autorización previa, expresa, informada y verificable, cuando sea exigible.
- **Uso de los datos:** garantizar que la información se utilice únicamente para la finalidad autorizada por el titular o permitida por la ley.
- **Acceso interno:** restringir el acceso a los datos personales exclusivamente al personal autorizado según sus funciones.
- **Evidencia:** conservar los soportes y registros necesarios para demostrar el cumplimiento de las obligaciones en procesos de verificación o auditoría.

Ejemplo:

Una tienda virtual solicita el nombre, la dirección, el número telefónico y el correo electrónico de sus clientes para gestionar la compra y realizar la entrega de un producto. Cuando informa claramente esta finalidad y obtiene la autorización correspondiente, puede utilizar los datos para ejecutar el proceso de venta. Si posteriormente desea enviar campañas publicitarias, deberá contar con una autorización específica para esa nueva finalidad.

Aplicación práctica

Antes de utilizar una base de datos para una nueva campaña comercial, la organización debe verificar que la finalidad correspondiente haya sido autorizada por los titulares. Si no existe evidencia suficiente, deberá abstenerse de utilizar la información hasta obtener la autorización requerida o identificar otra base legal que permita el tratamiento.

Las situaciones más frecuentes relacionadas con el tratamiento sin autorización se presentan a continuación:

Tabla 7. Riesgos y acciones para garantizar una autorización válida en el tratamiento de datos personales

Situación	Riesgo asociado	Acción recomendada
Compra de una base de datos sin soporte.	Uso de información sin consentimiento.	Verificar el origen de la información y las autorizaciones antes de utilizarla.
Envío de publicidad sin autorización.	Reclamaciones por uso indebido de datos personales.	Obtener autorización específica o excluir los contactos de las campañas.
Compartir datos con terceros sin respaldo legal.	Divulgación no autorizada de información personal.	Formalizar la autorización correspondiente o contar con otra base legal válida.
Formularios sin información sobre la finalidad.	Falta de transparencia en el tratamiento.	Ajustar los formatos e incorporar la información requerida por la normativa.
Uso de datos para finalidades diferentes a las autorizadas.	Incumplimiento del principio de finalidad.	Obtener una nueva autorización antes de realizar el tratamiento adicional.

Actividades de aplicación y análisis de los derechos de los titulares y las condiciones de legalidad

Se invita a leer el documento Actividades de aplicación y análisis de los derechos de los titulares y las condiciones de legalidad que se encuentra en la carpeta de anexos, donde se aborda la aplicación práctica de los derechos de los titulares, la autorización para el tratamiento de datos personales y las condiciones de legalidad establecidas en la Ley 1581 de 2012.

6. Responsables y encargados del tratamiento

El tratamiento de datos personales dentro de una organización involucra diferentes personas, áreas, proveedores, sistemas y terceros que participan en la recolección, el almacenamiento, el uso, la circulación, la actualización y la supresión de la información. Por esta razón, es indispensable identificar quién toma las decisiones sobre los datos, quién ejecuta las actividades de tratamiento y cuáles son las responsabilidades que corresponden a cada actor.

La Ley 1581 de 2012 establece dos figuras fundamentales para la gestión de los datos personales: el responsable del tratamiento y el encargado del tratamiento. Esta diferenciación permite definir quién determina las finalidades y condiciones del tratamiento y quién desarrolla las actividades sobre los datos siguiendo las instrucciones del responsable. La correcta identificación de estos roles facilita el cumplimiento de la normativa, fortalece la protección de la información y permite atender adecuadamente los derechos de los titulares.

6.1. Responsable del tratamiento

El responsable del tratamiento es la persona natural o jurídica, pública o privada, que decide sobre la base de datos o sobre el tratamiento de los datos personales. Es quien determina qué información se recopila, con qué finalidad se utiliza, durante cuánto tiempo se conserva y bajo qué condiciones puede compartirse.

Aunque una organización delegue actividades operativas en proveedores o terceros, continúa siendo responsable frente a los titulares cuando mantiene el control sobre las finalidades y las decisiones relacionadas con el tratamiento de los datos

personales. Los principales aspectos relacionados con el responsable del tratamiento se presentan a continuación:

- **Concepto y alcance.** El responsable del tratamiento es quien define las finalidades, los medios y las condiciones para el tratamiento de los datos personales. Su responsabilidad comprende todas las etapas del ciclo de vida de la información, desde la recolección hasta la supresión de los datos, garantizando el cumplimiento de la Ley 1581 de 2012 y la protección de los derechos de los titulares.
- **Funciones principales.** Entre sus funciones se encuentran definir la finalidad del tratamiento, informar al titular sobre el uso de sus datos, obtener la autorización cuando sea necesaria, conservar las evidencias correspondientes, garantizar el ejercicio de los derechos de los titulares, implementar medidas de seguridad y supervisar el cumplimiento de las obligaciones por parte de los encargados del tratamiento.
- **Obligaciones legales.** El responsable debe garantizar que el tratamiento se realice conforme a la normativa, proteger la información, conservar las autorizaciones, atender consultas y reclamaciones, actualizar los datos cuando corresponda, supervisar a los encargados y demostrar el cumplimiento de las disposiciones legales mediante políticas, procedimientos y controles adecuados.

Los principales elementos que caracterizan al responsable del tratamiento se presentan a continuación:

- **¿Quién es?** Persona natural o jurídica, pública o privada, que decide sobre el tratamiento de los datos personales.

- **¿Qué define?** Las finalidades, los medios de tratamiento, la conservación y la circulación de los datos.
- **¿Frente a quién responde?** Frente a los titulares de los datos y las autoridades competentes.
- **Responsabilidad principal.** Garantizar el cumplimiento de la normativa sobre protección de datos personales.
- **Ejemplo.** Empresa que recopila datos de clientes para prestar un servicio.

Ejemplo Aplicado

Una empresa de comercio electrónico solicita el nombre, la dirección, el teléfono, el correo electrónico y los datos necesarios para procesar las compras de sus clientes. Como define qué información recopila, con qué finalidad la utiliza y cómo será administrada, actúa como responsable del tratamiento.

Aplicación práctica

Antes de iniciar un nuevo tratamiento de datos personales, el responsable puede utilizar una matriz de verificación como la siguiente para comprobar el cumplimiento de sus obligaciones:

Tabla 8. Lista de verificación para el cumplimiento del tratamiento de datos personales

Pregunta de verificación	Sí	No	Acción requerida
¿La finalidad del tratamiento está claramente definida?			Definir y documentar una finalidad específica.

Pregunta de verificación	Sí	No	Acción requerida
¿Solo se recopilan los datos estrictamente necesarios?			Eliminar la información que no resulte pertinente.
¿Existe autorización cuando la normativa la exige?			Implementar un mecanismo de obtención de autorizaciones.
¿Se conserva evidencia del consentimiento?			Organizar un repositorio de soportes y registros.
¿Existe un canal para consultas y reclamaciones?			Designar responsables y establecer procedimientos de atención.
¿Se aplican medidas de seguridad sobre la información?			Implementar controles técnicos, administrativos y organizacionales.

6.2. Encargado del tratamiento

El encargado del tratamiento es la persona natural o jurídica, pública o privada, que realiza el tratamiento de datos personales por cuenta del responsable. A diferencia del responsable, el encargado no define la finalidad del tratamiento, sino que ejecuta las actividades relacionadas con los datos siguiendo las instrucciones recibidas.

Esta figura es frecuente cuando las organizaciones contratan proveedores tecnológicos, empresas de archivo, servicios de nómina, plataformas de correo electrónico, sistemas de gestión académica, servicios de almacenamiento en la nube, empresas de mensajería, call centers u otras entidades que requieren acceso a datos personales para prestar un servicio.

Aunque el encargado no determina la finalidad del tratamiento, tiene obligaciones específicas relacionadas con la protección de la información. Entre ellas se encuentran garantizar la confidencialidad, aplicar medidas de seguridad, cumplir las instrucciones impartidas por el responsable y abstenerse de utilizar los datos para fines distintos de los autorizados.

La relación entre el responsable y el encargado debe formalizarse mediante documentos que definan las responsabilidades, las condiciones del tratamiento, las medidas de seguridad y las actuaciones que deberán realizarse al finalizar la relación contractual. Los principales aspectos relacionados con el encargado del tratamiento se presentan a continuación:

- **Concepto y alcance.** El encargado del tratamiento realiza operaciones sobre los datos personales por cuenta del responsable y conforme a sus instrucciones. Su intervención puede comprender actividades como el almacenamiento de información, la administración de plataformas, el procesamiento de nómina, la custodia documental, el soporte tecnológico o cualquier otra labor que implique acceso a datos personales. No puede utilizar la información para finalidades propias ni conservarla una vez finalice la prestación del servicio, salvo que exista una obligación legal o una instrucción expresa del responsable.
- **Responsabilidades operativas.** El encargado debe tratar los datos únicamente para cumplir el servicio contratado, proteger la información mediante medidas técnicas, administrativas y organizacionales, mantener la confidencialidad, limitar el acceso al personal autorizado, informar

oportunamente los incidentes de seguridad y apoyar al responsable en la atención de consultas y solicitudes de los titulares.

- **Relación con el responsable.** La relación entre ambas partes debe sustentarse en contratos, acuerdos de tratamiento de datos, cláusulas de confidencialidad y demás documentos que definan las instrucciones, los controles de seguridad, las responsabilidades de cada parte y el procedimiento para la devolución, eliminación o bloqueo de la información cuando finalice el contrato.

Los principales elementos que caracterizan al encargado del tratamiento se presentan a continuación:

- **Quién es:** persona natural o jurídica que realiza el tratamiento de datos personales por cuenta del responsable del tratamiento.
- **Qué hace:** ejecuta las operaciones de recolección, almacenamiento, uso, circulación o supresión de los datos personales conforme a las instrucciones recibidas.
- **Qué no debe hacer:** definir finalidades propias ni utilizar los datos personales para fines distintos a los autorizados o instruidos por el responsable.
- **Fuente de instrucciones:** actúa de acuerdo con las directrices impartidas por el responsable del tratamiento.
- **Ejemplo:** proveedor que administra una base de datos de clientes en una plataforma de almacenamiento en la nube por cuenta de una organización.

Ejemplo Aplicado

Una empresa contrata un proveedor de software para administrar la nómina de sus trabajadores. El proveedor procesa información laboral y financiera siguiendo las instrucciones impartidas por la empresa. En este caso, el proveedor actúa como encargado del tratamiento.

Las principales responsabilidades del encargado del tratamiento son las siguientes:

- **Seguir las instrucciones del responsable.** Utilizar los datos únicamente para prestar el servicio contratado.
- **Garantizar la seguridad de la información.** Implementar controles de acceso, cifrado, copias de respaldo y demás medidas de protección.
- **Mantener la confidencialidad.** Evitar la divulgación o el uso no autorizado de la información.
- **Reportar incidentes de seguridad.** Informar oportunamente cualquier situación que pueda afectar la protección de los datos personales.
- **Limitar los accesos internos.** Permitir el acceso únicamente al personal autorizado para desarrollar el servicio.
- **Devolver, eliminar o bloquear la información.** Cumplir las instrucciones del responsable cuando finalice la relación contractual.
- **Apoyar la atención de los derechos de los titulares.** Facilitar la información necesaria para atender consultas, reclamaciones y demás solicitudes.

Aplicación práctica

Antes de contratar un proveedor que tendrá acceso a datos personales, la organización debe verificar los siguientes aspectos:

- Datos personales a los que tendrá acceso el proveedor: definir el tipo y el alcance de la información que podrá tratar durante la ejecución del contrato.
- Finalidad del acceso: verificar que el tratamiento de los datos responda exclusivamente al servicio contratado y a las instrucciones del responsable.
- Medidas de seguridad implementadas: confirmar que el proveedor aplica controles técnicos, administrativos y organizacionales adecuados para proteger la información.
- Personal autorizado para acceder a los datos: limitar el acceso únicamente a las personas que lo requieran para el cumplimiento de sus funciones.
- Tratamiento de la información al finalizar el contrato: establecer si los datos personales serán devueltos, eliminados o bloqueados una vez concluida la relación contractual.
- Gestión de incidentes de seguridad: definir el procedimiento para reportar, atender y documentar los incidentes que puedan afectar la información.
- Acuerdos de confidencialidad y tratamiento de datos: formalizar las obligaciones, responsabilidades y compromisos de las partes respecto a la protección de los datos personales.

6.3. Gestión organizacional del tratamiento de datos

La gestión organizacional del tratamiento de datos comprende el conjunto de roles, procedimientos, controles y documentos que permiten administrar la información personal de manera organizada, segura y conforme a la Ley 1581 de 2012.

Su propósito es integrar la protección de datos a los procesos cotidianos de la organización y garantizar que el cumplimiento normativo se refleje en las actividades diarias.

Contar con políticas institucionales no es suficiente si no existen responsables claramente definidos, procedimientos documentados, controles de acceso, mecanismos para atender los derechos de los titulares y evidencias que respalden el tratamiento de la información. Por ello, la protección de datos debe incorporarse como parte de la gestión organizacional y no limitarse a un requisito documental.

Una adecuada gestión también reduce la improvisación, fortalece la coordinación entre las diferentes áreas y mejora la capacidad de respuesta frente a consultas, reclamaciones, auditorías e incidentes de seguridad. Los principales componentes de la gestión organizacional del tratamiento de datos se presentan a continuación:

- **Roles internos.** La organización debe definir responsabilidades para las áreas y personas que intervienen en el tratamiento de datos personales. Cada dependencia debe conocer sus funciones, los procedimientos que debe aplicar y la forma de atender las obligaciones relacionadas con la protección de la información.
- **Procedimientos de control.** Corresponden a los procesos documentados que regulan actividades como la recolección, actualización, consulta, almacenamiento, acceso, transferencia, supresión de datos, gestión de autorizaciones, atención de solicitudes y respuesta a incidentes de seguridad. Su aplicación permite estandarizar las actuaciones y reducir riesgos de incumplimiento.

- **Documentación requerida.** Comprende las políticas, procedimientos, registros y demás documentos que permiten demostrar el cumplimiento de la normativa. Esta documentación debe mantenerse actualizada, organizada y disponible para las áreas autorizadas y para las autoridades competentes cuando sea necesario.

La gestión del tratamiento de datos requiere la participación coordinada de diferentes áreas de la organización. Los principales roles internos se presentan a continuación:

- **Alta dirección.** Aprobar las políticas institucionales, asignar recursos y respaldar el cumplimiento de la normativa.
- **Área jurídica.** Asesorar sobre los requisitos legales, revisar autorizaciones y apoyar la atención de consultas y reclamaciones.
- **Tecnología.** Implementar controles de seguridad, administrar accesos y proteger los sistemas de información.
- **Talento humano.** Gestionar y proteger los datos personales de trabajadores, candidatos y contratistas.
- **Mercadeo.** Utilizar bases de datos únicamente para las finalidades autorizadas.
- **Servicio al cliente.** Recibir y gestionar consultas, solicitudes y reclamaciones de los titulares.
- **Archivo o gestión documental.** Custodiar los soportes físicos y digitales relacionados con el tratamiento de datos.
- **Coordinador de protección de datos.** Coordinar los procedimientos, realizar seguimiento al cumplimiento y promover la mejora continua.

Ejemplo:

En una empresa comercial, el área de mercadeo desea desarrollar una campaña dirigida a antiguos clientes. Antes de utilizar la base de datos, verifica con el responsable de protección de datos que exista autorización para esa finalidad. Posteriormente, el área de tecnología garantiza la seguridad de la información y el servicio de atención al cliente dispone de los mecanismos necesarios para atender solicitudes de actualización, revocatoria o supresión.

Los procedimientos de control permiten estandarizar el tratamiento de los datos personales y garantizar actuaciones uniformes en toda la organización.

Tabla 9. Procedimientos para la gestión del tratamiento de datos personales y sus evidencias

Procedimiento	Propósito	Evidencia recomendada
Recolección de datos	Garantizar la finalidad del tratamiento y la obtención de la autorización cuando corresponda.	Formulario, aviso de privacidad y evidencia de la autorización.
Actualización de datos	Mantener la información exacta y actualizada.	Solicitud del titular y registro de la actualización realizada.
Atención de consultas y reclamaciones	Garantizar el ejercicio de los derechos de los titulares.	Radicado, respuesta y registro de seguimiento.
Control de accesos	Restringir el acceso a la información al personal autorizado.	Matriz de permisos y registros de acceso.
Gestión de proveedores	Supervisar el tratamiento realizado por los encargados.	Contratos, acuerdos de tratamiento y evaluaciones de seguridad.

Procedimiento	Propósito	Evidencia recomendada
Gestión de incidentes	Atender oportunamente pérdidas, accesos no autorizados o vulneraciones de seguridad.	Reportes de incidentes, análisis y acciones correctivas.
Supresión de datos	Eliminar, bloquear o anonimizar la información cuando proceda.	Acta, registro o evidencia del procedimiento realizado.

Aplicación práctica

La documentación relacionada con el tratamiento de datos personales debe mantenerse organizada, actualizada y protegida mediante controles de acceso. Asimismo, es recomendable establecer responsables de su administración, fechas de revisión periódica y mecanismos de control de versiones que permitan asegurar que toda la organización utilice los documentos vigentes.

7. Vigilancia, control y sanciones

La protección de los datos personales no depende únicamente del compromiso de las organizaciones. Para garantizar el cumplimiento de la Ley 1581 de 2012. Existen mecanismos de vigilancia, control y sanción orientados a verificar que los responsables y encargados del tratamiento actúen conforme a la normativa vigente.

Estos mecanismos buscan proteger los derechos de los titulares frente a situaciones como el uso no autorizado de datos personales, la ausencia de políticas de tratamiento, la falta de respuesta a consultas o reclamaciones, la divulgación indebida de información, la pérdida de bases de datos o el incumplimiento de las medidas de seguridad.

En el contexto organizacional, conocer el funcionamiento de estos mecanismos permite prevenir riesgos legales, fortalecer los controles internos y demostrar el cumplimiento de las obligaciones relacionadas con el tratamiento de datos personales.

Además de su función correctiva, la vigilancia y el control cumplen un propósito preventivo, ya que promueven la adopción de buenas prácticas, la mejora continua de los procesos y el fortalecimiento de la cultura organizacional en materia de protección de datos.

7.1. Autoridades de control

Las autoridades de control son las entidades encargadas de vigilar el cumplimiento de las normas relacionadas con la protección de datos personales. Su función consiste en verificar que los responsables y encargados del tratamiento respeten los derechos de los titulares y cumplan las obligaciones establecidas por la normativa.

En Colombia, la Superintendencia de Industria y Comercio (SIC) ejerce la autoridad nacional de protección de datos personales. Entre sus funciones se encuentran recibir quejas, adelantar investigaciones, impartir instrucciones, realizar actividades de inspección y vigilancia, ordenar medidas correctivas e imponer sanciones cuando se evidencien incumplimientos.

Para las organizaciones, la existencia de una autoridad de control implica la necesidad de conservar evidencias que demuestren el cumplimiento de la normativa. Las políticas, autorizaciones, procedimientos, registros, contratos y controles de seguridad constituyen elementos esenciales para acreditar una gestión adecuada del tratamiento de los datos personales. Los principales aspectos relacionados con las autoridades de control se presentan a continuación:

- **Funciones de supervisión.** Consisten en verificar que las organizaciones realicen el tratamiento de datos personales conforme a la normativa. La supervisión puede originarse por quejas de los titulares, actuaciones de oficio, requerimientos de información o investigaciones administrativas. Durante este proceso se revisan políticas, autorizaciones, medidas de seguridad, atención de derechos y procedimientos internos para determinar el nivel de cumplimiento de la organización.
- **Facultades de inspección.** Permiten solicitar información, revisar documentos, requerir explicaciones, evaluar procedimientos y verificar las medidas implementadas para proteger los datos personales. Estas actuaciones pueden dar lugar a recomendaciones, requerimientos, medidas correctivas o, cuando corresponda, al inicio de investigaciones administrativas.

- **Procesos de investigación.** Se desarrollan cuando existen indicios de posibles incumplimientos en el tratamiento de datos personales. Durante la investigación se analizan los hechos, las evidencias, las actuaciones de la organización y las posibles afectaciones a los titulares. Como resultado, la autoridad puede ordenar acciones correctivas o imponer las sanciones previstas en la normativa.

Las principales actividades objeto de supervisión se presentan a continuación:

- **Política de tratamiento de datos personales.** Que exista, se encuentre actualizada y esté disponible para los titulares.
- **Autorizaciones.** Que sean previas, expresas, informadas y verificables.
- **Finalidad del tratamiento.** Que la información se utilice únicamente para las finalidades informadas al titular.
- **Atención de los derechos de los titulares.** Que existan canales de atención y respuestas oportunas a consultas y reclamaciones.
- **Seguridad de la información.** Que se implementen medidas técnicas, administrativas y organizacionales para proteger los datos.
- **Relación con los encargados del tratamiento.** Que existan contratos, instrucciones y controles sobre los proveedores que tratan datos personales.

Ejemplo:

Una empresa continúa enviando mensajes promocionales a un cliente que previamente solicitó ser retirado de la base de datos comercial. Ante la reclamación presentada, la autoridad de control puede verificar si la organización atendió la solicitud, actualizó la base de datos y conservó las evidencias correspondientes.

Aplicación práctica

Para facilitar una eventual actividad de supervisión, la organización debe mantener organizada y actualizada la documentación relacionada con la protección de datos personales, incluyendo las autorizaciones, las políticas de tratamiento, los registros de solicitudes, las respuestas suministradas a los titulares, los contratos con encargados y las evidencias de las medidas de seguridad implementadas. Los principales documentos que pueden ser requeridos durante una inspección son los siguientes:

- **Política de tratamiento de datos personales.** Demostrar las reglas generales para el tratamiento de la información.
- **Aviso de privacidad.** Evidenciar la información suministrada a los titulares.
- **Autorizaciones.** Acreditar el consentimiento otorgado por los titulares cuando sea exigible.
- **Inventario de bases de datos.** Identificar la información administrada por la organización.
- **Matriz de riesgos.** Evidenciar el análisis y la gestión de riesgos asociados al tratamiento de datos.
- **Contratos con encargados.** Demostrar el control ejercido sobre los terceros que procesan datos personales.
- **Registro de incidentes.** Documentar los eventos de seguridad y las acciones correctivas implementadas.
- **Plan de capacitación.** Evidenciar las actividades de formación realizadas al personal.

EjemploUna institución educativa recibe un requerimiento para explicar cómo protege los datos personales de sus estudiantes menores de edad. Para responder, presenta las políticas institucionales, las autorizaciones otorgadas por los acudientes, los procedimientos de acceso a las plataformas académicas y las medidas de seguridad implementadas para proteger la información.

Aplicación práctica

Toda organización debe establecer un procedimiento para atender requerimientos de las autoridades de control. Este procedimiento debe definir quién recibe la comunicación, qué áreas participan en la preparación de la respuesta, cómo se recopilan las evidencias, quién valida la información antes de su envío y cómo se conservan los soportes relacionados con el proceso.

7.2. Régimen sancionatorio

El régimen sancionatorio establece las consecuencias que pueden imponerse cuando una organización incumple las obligaciones relacionadas con la protección de datos personales. Su finalidad es corregir prácticas contrarias a la normativa, proteger los derechos de los titulares y promover una gestión responsable de la información.

Las sanciones pueden derivarse de situaciones como la recolección de datos sin autorización, el uso de información para finalidades diferentes a las informadas, la falta de atención de los derechos de los titulares, el incumplimiento de las medidas de seguridad, la divulgación indebida de datos personales o el desconocimiento de las instrucciones impartidas por la autoridad competente.

El régimen sancionatorio aplica a cualquier organización que realice tratamiento de datos personales, independientemente de su tamaño o actividad económica. Por

ello, resulta fundamental implementar controles preventivos que permitan reducir los riesgos de incumplimiento y fortalecer la cultura institucional de protección de datos. Los principales aspectos relacionados con el régimen sancionatorio se presentan a continuación:

- **Tipos de infracciones.** Las infracciones corresponden a acciones u omisiones que vulneran los principios, derechos y obligaciones establecidos en la normativa sobre protección de datos personales. Pueden originarse por la recolección indebida de información, la ausencia de autorización, el uso no autorizado de los datos, la falta de atención de los derechos de los titulares, la divulgación de información sin fundamento legal, las fallas de seguridad o el incumplimiento de las órdenes impartidas por la autoridad competente.
- **Sanciones aplicables.** Cuando se comprueba un incumplimiento, la autoridad competente puede imponer medidas como multas, órdenes de corrección, suspensión de actividades relacionadas con el tratamiento de datos, cierre temporal de operaciones asociadas a bases de datos y otras actuaciones previstas en la normativa. Además del impacto económico, estas medidas pueden afectar la reputación, la confianza y la continuidad de los procesos organizacionales.
- **Medidas correctivas.** Corresponden a las acciones implementadas por la organización para eliminar las causas que originaron el incumplimiento y prevenir su repetición. Estas medidas deben documentarse, asignarse a responsables, ejecutarse dentro de plazos definidos y verificarse posteriormente para evaluar su eficacia.

Las principales infracciones relacionadas con el tratamiento de datos personales se presentan a continuación:

- **Recolección indebida.** Solicitar datos personales sin informar la finalidad del tratamiento.
- **Ausencia de autorización.** Utilizar datos personales sin contar con la autorización cuando esta sea exigible.
- **Uso no autorizado.** Emplear la información para finalidades diferentes de las informadas al titular.
- **Incumplimiento en la atención de derechos.** No responder consultas, reclamaciones o solicitudes de actualización, rectificación o supresión.
- **Divulgación indebida.** Compartir datos personales con terceros sin fundamento legal o autorización.
- **Falla de seguridad.** Permitir accesos no autorizados, pérdida o alteración de la información.
- **Incumplimiento de órdenes.** No atender las instrucciones impartidas por la autoridad competente.

Ejemplo:

Una empresa recopila datos de los asistentes a un evento académico y posteriormente utiliza esa información para enviar publicidad de terceros sin haber informado esa finalidad ni contar con la autorización correspondiente. Esta actuación puede constituir una infracción por utilizar los datos para fines no autorizados.

Aplicación práctica

Para disminuir el riesgo de sanciones, las organizaciones deben revisar periódicamente sus bases de datos, validar las autorizaciones obtenidas, actualizar sus políticas y procedimientos, capacitar al personal, supervisar el tratamiento realizado por terceros y mantener organizada la documentación que respalde el cumplimiento de la normativa. Las principales medidas correctivas que pueden implementarse frente a hallazgos relacionados con el tratamiento de datos personales son las siguientes:

Tabla 10. Hallazgos frecuentes y medidas correctivas para el cumplimiento de la protección de datos personales

Hallazgo identificado	Medida correctiva recomendada
No existe política de tratamiento de datos personales.	Elaborar, aprobar, publicar y divulgar la política institucional.
Autorizaciones incompletas o insuficientes.	Actualizar los formatos y obtener evidencias válidas de autorización.
Bases de datos sin soporte documental.	Depurar la información y verificar las finalidades autorizadas.
Accesos excesivos a la información.	Implementar una matriz de permisos basada en roles y funciones.
Proveedores sin obligaciones relacionadas con protección de datos.	Actualizar los contratos e incorporar cláusulas específicas para los encargados del tratamiento.
Personal sin formación en protección de datos.	Desarrollar programas de capacitación y sensibilización.
Ausencia de canales para consultas y reclamaciones.	Diseñar e implementar un procedimiento formal para la atención de los titulares.

7.3. Gestión del riesgo legal

La gestión del riesgo legal consiste en identificar, evaluar y controlar las situaciones que pueden generar incumplimientos de la normativa sobre protección de datos personales. Su propósito es prevenir sanciones, proteger los derechos de los titulares y fortalecer el cumplimiento de las obligaciones establecidas en la Ley 1581 de 2012.

Este enfoque permite anticiparse a los riesgos antes de que se conviertan en incidentes, reclamaciones o investigaciones administrativas. Actividades como revisar periódicamente las bases de datos, validar las autorizaciones, capacitar al personal, supervisar a los encargados del tratamiento y actualizar la documentación contribuyen a reducir la probabilidad de incumplimientos.

La gestión del riesgo legal debe incorporarse a los procesos organizacionales como una actividad permanente de planificación, seguimiento y mejora continua. De esta manera, la organización fortalece su capacidad para responder oportunamente ante auditorías, requerimientos de las autoridades, incidentes de seguridad o solicitudes presentadas por los titulares. Los principales componentes de la gestión del riesgo legal se presentan a continuación:

- **Identificación de riesgos.** Consiste en reconocer las situaciones que pueden afectar el cumplimiento de la normativa durante la recolección, el almacenamiento, el uso, la circulación y la eliminación de datos personales. Esta actividad permite priorizar los riesgos según su probabilidad e impacto y definir los controles necesarios para prevenirlos.
- **Prevención de incumplimientos.** Comprende la implementación de medidas orientadas a reducir la probabilidad de vulneraciones relacionadas con el

tratamiento de datos personales. Estas medidas incluyen la revisión de formularios, la validación de autorizaciones, la capacitación del personal, el control de accesos, la evaluación de proveedores, las auditorías internas y la actualización permanente de políticas y procedimientos.

- **Cultura de protección de datos.** Corresponde al conjunto de prácticas, hábitos y comportamientos que promueven la protección permanente de la información dentro de la organización. Esta cultura requiere el compromiso de la alta dirección, la definición de responsabilidades, la formación continua del personal y el fortalecimiento de la conciencia sobre la importancia de proteger los datos personales en todas las actividades institucionales.

La identificación de riesgos permite reconocer las principales situaciones que pueden afectar el tratamiento de los datos personales.

Tabla 11. Riesgos, causas e impactos en el tratamiento de datos personales

Riesgo identificado	Posible causa	Impacto
Uso de datos sin autorización	Bases de datos antiguas sin soportes de autorización.	Reclamaciones de titulares e investigaciones administrativas.
Divulgación indebida de información	Envío de archivos a destinatarios incorrectos.	Vulneración de la privacidad y pérdida de confianza.
Acceso no autorizado	Permisos excesivos o controles insuficientes en los sistemas de información.	Exposición de datos personales.
Datos desactualizados	Ausencia de procedimientos para la actualización de la información.	Decisiones incorrectas y fallas en las comunicaciones.

Riesgo identificado	Posible causa	Impacto
Proveedores sin controles adecuados	Contratos que no incluyen obligaciones relacionadas con la protección de datos.	Uso indebido de la información por terceros.
Pérdida de información	Ausencia de copias de seguridad o fallas en los sistemas.	Interrupción de procesos y afectación de los derechos de los titulares.

Ejemplo:

Una empresa identifica que todos los integrantes del área comercial pueden descargar la base completa de clientes sin restricciones. Este hallazgo evidencia un riesgo de acceso excesivo que puede facilitar el uso indebido o la divulgación no autorizada de la información.

Aplicación práctica

Para identificar los riesgos asociados al tratamiento de datos personales, la organización puede realizar una revisión de cada uno de sus procesos utilizando una matriz de análisis como la siguiente:

- **¿Qué datos personales se recopilan?** Identificar la información objeto de tratamiento.
- **¿Cuál es la finalidad del tratamiento?** Verificar que exista una finalidad legítima y documentada.
- **¿Quién tiene acceso a la información?** Determinar los usuarios autorizados.
- **¿Dónde se almacenan los datos?** Identificar los medios físicos o digitales utilizados.

- **¿Con quién se comparte la información?** Verificar la existencia de terceros involucrados en el tratamiento.
- **¿Qué podría afectar la protección de los datos?** Identificar amenazas y vulnerabilidades.
- **¿Qué controles existen actualmente?** Evaluar las medidas implementadas para reducir los riesgos.

Las principales medidas para prevenir incumplimientos relacionados con la protección de datos personales se presentan a continuación:

- **Capacitación periódica del personal.** Fortalecer el conocimiento sobre las obligaciones relacionadas con el tratamiento de datos.
- **Revisión de formularios.** Garantizar una recolección de información conforme a la normativa.
- **Control de accesos.** Reducir el riesgo de consultas o modificaciones no autorizadas.
- **Validación de autorizaciones.** Confirmar que los datos solo se utilicen para las finalidades permitidas.
- **Evaluación de proveedores.** Verificar que los encargados del tratamiento implementen medidas adecuadas de protección.
- **Auditorías internas.** Detectar oportunamente incumplimientos y oportunidades de mejora.
- **Actualización documental.** Mantener vigentes las políticas, procedimientos y demás documentos institucionales.

Ejemplo:

Antes de iniciar una campaña comercial, una empresa revisa las autorizaciones otorgadas por los titulares para recibir comunicaciones promocionales. Los registros que no cuentan con evidencia suficiente son excluidos de la campaña hasta verificar el cumplimiento de las condiciones de legalidad.

Protección de datos personales: casos de análisis y práctica sobre cumplimiento normativo

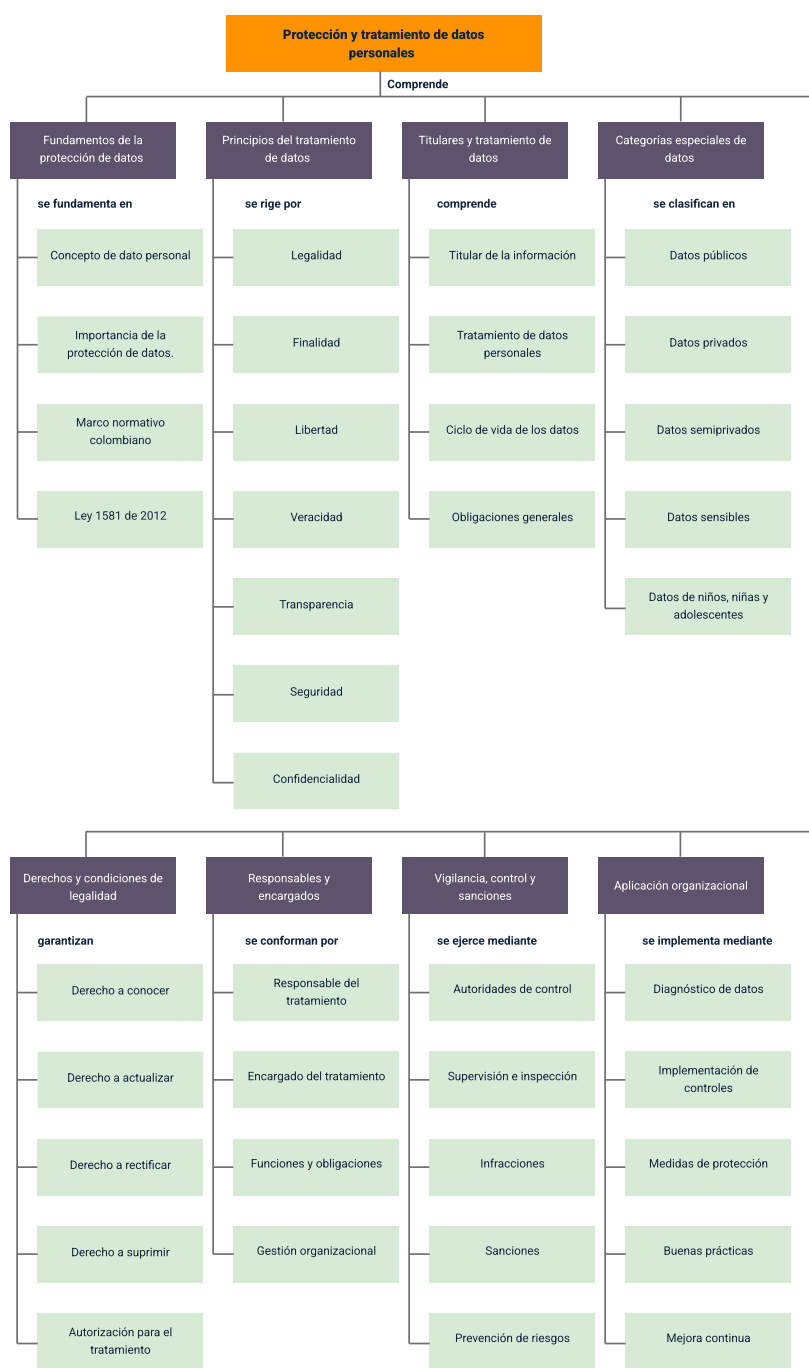
Se invita a leer el documento Protección de Datos Personales: Casos de análisis y práctica sobre cumplimiento normativo que se encuentra en la carpeta de anexos, donde se abordan situaciones organizacionales relacionadas con el cumplimiento de la Ley 1581 de 2012 mediante casos prácticos enfocados en inspecciones de la autoridad de control, acceso no autorizado a datos sensibles, atención de los derechos de los titulares y uso de bases de datos sin autorización verificable.

Aplicación organizacional de la protección de datos personales

Se invita a leer el documento Aplicación organizacional de la protección de datos personales que se encuentra en la carpeta de anexos, donde se aborda la implementación práctica de la protección de datos personales en las organizaciones, a partir de las políticas de tratamiento, las medidas administrativas, técnicas y físicas de seguridad, las buenas prácticas y la mejora continua, conforme a la Ley 1581 de 2012.

Síntesis

A continuación, se presenta una síntesis de la temática estudiada en el componente formativo.



Glosario

Acceso restringido: principio que establece que los datos personales solo pueden ser consultados por personas autorizadas y para las finalidades permitidas.

Base de datos: conjunto organizado de datos personales que es objeto de tratamiento.

Confidencialidad: obligación de proteger la información y evitar que sea conocida o utilizada por personas no autorizadas.

Dato personal: información vinculada o asociada a una persona natural identificada o identificable.

Finalidad: propósito específico, legítimo e informado para el cual se recopilan y utilizan los datos personales.

Habeas data: derecho fundamental que permite conocer, actualizar, rectificar y controlar la información personal que reposa en bases de datos.

Ley 1581 de 2012: norma colombiana que establece el régimen general de protección de datos personales y regula su tratamiento.

Protección de datos personales: conjunto de principios, normas, procedimientos y medidas orientados a garantizar un tratamiento legal, seguro y responsable de la información personal.

Titular: persona natural a quien pertenecen los datos personales objeto de tratamiento.

Veracidad: principio que exige que los datos personales sean exactos, completos, verificables y actualizados.

Referencias bibliográficas

Congreso de la República de Colombia. (2012). Ley 1581 de 2012. Por la cual se dictan disposiciones generales para la protección de datos personales. Función Pública. <https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=49981>

Constitución Política de Colombia. (1991). Constitución Política de Colombia. Artículo 15. Constitución Colombia. <https://www.constitucioncolombia.com/titulo-2/capitulo-1/articulo-15>

RISKS International. (2024, 25 de julio). Protección de datos personales en Colombia: Derechos, clasificación y normativas.

Superintendencia de Industria y Comercio. (2023). Protección de datos personales. <https://www.sic.gov.co/proteccion-de-datos-personales>

Universidad Nacional Abierta y a Distancia. (2025, 27 de enero). Lo que debes saber sobre el tratamiento y protección de datos personales. Noticias UNAD. https://noticias.unad.edu.co/index.php/noticias-unad/lo-que-debes-saber-sobre-el-tratamiento-y-proteccion-de-datos-personales?filter_tag%5B0%5D=208

Créditos

Nombre	Cargo	Centro de Formación y Regional
Claudia Johanna Gómez Pérez	Profesional 06. Responsable Ecosistema Virtual de Recursos Educativos Digitales	Centro Agroturístico - Regional Santander
Joinner Enrique Osorio Martínez	Experto temático	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Paola Alexandra Moya	Evaluable instruccional	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Fredy Fabian Ortiz Segura	Diseñador de contenidos digitales	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Henry Alvarez Astudillo	Desarrollador full stack	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Alejandro Delgado Acosta	Intérprete lenguaje de señas	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Cristhian Giovanni Gordillo Segura	Intérprete Lenguaje de señas	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Juan Pablo Rojas Polania	Animador y productor multimedia	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Carlos Eduardo Garavito Parada	Animador y productor multimedia	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Maria Carolina Tamayo Lopez	Locución	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
German Acosta Ramos	Locución	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Aixa Natalia Sendoya Fernández	Validador de recursos educativos digitales	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila

Nombre	Cargo	Centro de Formación y Regional
Ricardo Oliveros Zambrano	Validador de recursos educativos digitales	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Anyerson Wilfredo Pizo Ossa	Evaluador para contenidos inclusivos y accesibles	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Daniel Ricardo Mutis Gómez	Evaluador para contenidos inclusivos y accesibles	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila